



**FACULTAD DE POSTGRADO
TRABAJO FINAL DE GRADUACIÓN**

**FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE
AMENAZAS (CTI) BASADO EN MITRE ATT&CK®,
GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD
NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE
AMENAZA EN HONDURAS**

SUSTENTADO POR:

**EDER JOSUE ARTICA CRUZ
SUYAPA INES MATAMOROS PACHECO**

PREVIA INVESTIDURA AL TÍTULO DE

**MÁSTER EN
CIBERSEGURIDAD**

TEGUCIGALPA, FRANCISCO MORAZAN, HONDURAS, C.A.

JUNIO, 2026

**UNIVERSIDAD TECNOLÓGICA CENTROAMERICANA
UNITEC**

FACULTAD DE POSTGRADO

AUTORIDADES UNIVERSITARIAS

RECTORA

ROSALPINA RODRÍGUEZ

VICERRECTOR ACADÉMICO NACIONAL

JAVIER ABRAHAM SALGADO LEZAMA

SECRETARIO GENERAL

ROGER MARTÍNEZ MIRALDA

DECANA FACULTAD DE POSTGRADO

ANA DEL CARMEN RETTALLY VARGAS

**FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE
AMENAZAS (CTI) BASADO EN MITRE ATT&CK®,
GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD
NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE
AMENAZA EN HONDURAS**

**TRABAJO PRESENTADO EN CUMPLIMIENTO DE LOS
REQUISITOS EXIGIDOS PARA OPTAR AL TÍTULO DE
MÁSTER EN
CIBERSEGURIDAD**

**ASESOR
SERVIO PALACIOS**

MIEMBROS DE LA TERNA:

**NOMBRE COMPLETO EVALUADOR 1
NOMBRE COMPLETO EVALUADOR 2
NOMBRE COMPLETO EVALUADOR 3**

DERECHOS DE AUTOR

© Copyright 2023
Eder Josué Artica Cruz
Suyapa Ines Matamoros Pacheco

Todos los derechos son reservados.

**AUTORIZACIÓN DEL AUTOR(ES) PARA LA CONSULTA,
REPRODUCCIÓN PARCIAL O TOTAL Y PUBLICACIÓN
ELECTRÓNICA DEL TEXTO COMPLETO DE TESIS DE POSTGRADO**

Señores

**CENTRO DE RECURSOS PARA EL APRENDIZAJE Y LA INVESTIGACIÓN (CRAI)
UNIVERSIDAD TECNOLÓGICA CENTROAMERICANA (UNITEC)**

Estimados Señores:

Yo, XXXXXXXXXXXX, de Tegucigalpa, (o San Pedro Sula, o La Ceiba) autor del trabajo de postgrado titulado: XXXXXXXXXXXXXXXXXXXXXXXXXXXX, presentado y aprobado en XXXX, como requisito previo para optar al título de máster en XXXXXXXXXXXXXXXXXXXX y reconociendo que la presentación del presente documento forma parte de los requerimientos establecidos del programa de maestrías de la Universidad Tecnológica Centroamericana (UNITEC), por este medio autorizo a las Bibliotecas de los Centros de Recursos para el Aprendizaje y la Investigación (CRAI) de UNITEC, para que con fines académicos puedan libremente registrar, copiar o utilizar la información contenida en él, con fines educativos, investigativos o sociales de la siguiente manera:

- 1) Los usuarios puedan consultar el contenido de este trabajo en las salas de estudio de la biblioteca y/o la página Web de la Universidad.
- 2) Permita la consulta y/o la reproducción a los usuarios interesados en el contenido de este trabajo, para todos los usos que tengan finalidad académica, ya sea en formato CD o digital desde Internet, Intranet, etc., y en general en cualquier otro formato conocido o por conocer.

De conformidad con lo establecido en los artículos 9.2, 18, 19, 35 y 62 de la Ley de Derechos de Autor y de los Derechos Conexos; los derechos morales pertenecen al autor y son personalísimos, irrenunciables, imprescriptibles e inalienables. Asimismo, el autor cede de forma ilimitada y exclusiva a UNITEC la titularidad de los derechos patrimoniales. Es entendido que cualquier copia o reproducción del presente documento con fines de lucro no está permitida sin previa autorización por escrito de parte de UNITEC.

En fe de lo cual se suscribe el presente documento en la ciudad de _____, a los ____ días del mes de _____ del año _____

Nombre completo

Número de cuenta

*** La autorización firmada se encuentra adjunta a mí expediente**



FACULTAD DE POSTGRADO

FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE AMENAZAS (CTI) BASADO EN MITRE ATT&CK®, GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN HONDURAS

Eder Josué Artica Cruz
Suyapa Ines Matamoros
Pacheco

Resumen

[illegible]

Palabras claves: (xxxxx



GRADUATE SCHOOL

FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE AMENAZAS (CTI) BASADO EN MITRE ATT&CK®, GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN HONDURAS

Eder Josue Artica Cruz
Suyapa Ines Matamoros
Pacheco

Abstract

[illegible]

Palabras claves: (xxxxx)

DEDICATORIA

[illegible]

AGRADECIMIENTO

Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su
agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca
aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento.
Introduzca aquí su agradecimiento. Introduzca aquí su agradecimiento. Introduzca aquí su
agradecimiento. Introduzca aquí su agradecimiento.

ÍNDICE DE CONTENIDO

DEDICATORIA.....	ix
AGRADECIMIENTO.....	x
ÍNDICE DE CONTENIDO.....	11
TABLA DE ILUSTRACIONES.....	14
CAPÍTULO I. PLANTEAMIENTO DE LA INVESTIGACIÓN.....	17
1.1 INTRODUCCIÓN.....	17
1.2 ANTECEDENTES DEL PROBLEMA.....	18
1.3 DEFINICIÓN DEL PROBLEMA.....	19
1.3.1 ENUNCIADO DEL PROBLEMA.....	19
1.3.2 FORMULACIÓN DEL PROBLEMA.....	20
1.3.3 PREGUNTAS DE INVESTIGACIÓN.....	20
1.4 OBJETIVOS DEL PROYECTO.....	21
1.5 JUSTIFICACIÓN.....	22
1.6 CONTRIBUCIONES Y ALCANCES.....	25
1.7 LIMITACIONES.....	26
CAPÍTULO II. MARCO TEÓRICO.....	27
2.1. ANÁLISIS DE LA SITUACIÓN ACTUAL.....	27
2.2. CONCEPTUALIZACIÓN.....	28
2.3. TEORÍAS DE SUSTENTO.....	30
2.3.1. BASES TEORICAS.....	30
2.3.2. METODOLOGÍAS DESARROLLADAS.....	32
2.3.3. INSTRUMENTOS UTILIZADOS.....	33
2.4. MARCO LEGAL.....	34
2.4.1. MARCO REGULATORIO NACIONAL.....	34
2.4.2. ESTÁNDARES INTERNACIONALES VINCULANTES EN EL ENTORNO NACIONAL.....	35
CAPÍTULO III. METODOLOGÍA.....	37
3.1. CONGRUENCIA METODOLÓGICA.....	37

3.1.1.	MATRIZ METODOLÓGICA.....	37
3.1.2.	ESQUEMA DE VARIABLES DE ESTUDIO.....	40
3.1.3.	OPERACIONALIZACIÓN DE LAS VARIABLES.....	41
3.1.4.	HIPÓTESIS.....	45
3.2.	ENFOQUE Y MÉTODOS.....	46
3.3.	DISEÑO DE LA INVESTIGACIÓN.....	47
3.3.4.	POBLACIÓN.....	47
3.3.5.	MUESTRA.....	47
3.3.6.	TÉCNICAS DE MUESTREO.....	49
3.4.	TÉCNICAS, INSTRUMENTOS Y PROCEDIMIENTOS APLICADOS.....	51
3.5.	FUENTES DE INFORMACIÓN.....	54
3.5.4.	FUENTES PRIMARIAS.....	54
3.5.5.	FUENTES SECUNDARIAS.....	54
3.6.	PIPELINE METODOLÓGICO Y DISEÑO DE SU ARQUITECTURA.....	55
3.6.1.	Fases operativas de la arquitectura.....	55
3.6.2.	Modelo de Amenazas del Artefacto (<i>Threat Model</i>) y Fronteras de Confianza.....	56
3.7.	ESTRATEGIA DE EVALUACIÓN.....	58
3.8.	AMENAZAS A LA VALIDEZ.....	59
3.9.	ÉTICA, PRIVACIDAD Y GOBERNANZA DE DATOS.....	60
	CAPÍTULO IV. RESULTADOS Y ANÁLISIS.....	63
4.1.	INFORME DE PROCESO DE RECOLECCIÓN DE DATOS.....	63
4.2.	RESULTADOS Y ANÁLISIS DE LAS TÉCNICAS APLICADAS.....	67
4.2.4.	RESULTADOS CUANTITATIVOS.....	67
4.2.5.	ANÁLISIS CUALITATIVO.....	72
4.3.	CONTRASTE INFERENCIAL DE HIPÓTESIS Y PRUEBAS ESTADÍSTICAS.....	78
4.3.4.	CONTRASTE DE HIPÓTESIS PARA LA TASA DE FALSOS POSITIVOS: PRUEBA DE MCNEMAR.....	78
4.3.5.	CONTRASTE DE HIPÓTESIS PARA VARIABLES TEMPORALES: PRUEBA DE RANGOS CON SIGNO DE WILCOXON.....	79
4.4.	ANÁLISIS INFERENCIAL Y MODELOS APLICADOS.....	81
	CAPÍTULO V. CONCLUSIONES Y RECOMENDACIONES.....	86

5.1	CONCLUSIONES.....	86
5.2	RECOMENDACIONES.....	88
5.3.	TABLA DE SISTEMATIZACIÓN Y CONTROL DE CONGRUENCIA DE LA INVESTIGACIÓN.....	90
	CAPÍTULO VI. APLICABILIDAD.....	93
6.1	NOMBRE DE LA PROPUESTA.....	93
6.2	JUSTIFICACIÓN DE LA PROPUESTA.....	93
6.3	ALCANCE DE LA PROPUESTA.....	94
6.4	DESCRIPCIÓN Y DESARROLLO.....	95
6.4.1	¿QUÉ SE HARÁ Y CÓMO SE HARÁ?.....	95
6.4.2	DESARROLLO.....	96
6.5	MEDIDAS DE CONTROL.....	106
6.6	CRONOGRAMA DE IMPLEMENTACIÓN.....	107
6.7	PRESUPUESTO E IMPACTO DEL PRESUPUESTO.....	109
6.1.4.	COSTOS ESTIMADOS DE IMPLEMENTACIÓN.....	109
6.1.5.	IMPACTO FINANCIERO Y ANÁLISIS DE RETORNO DE INVERSIÓN (ROI). 111	
6.8	CONCORDANCIA DE LOS SEGMENTOS DE LA TESIS CON LA PROPUESTA	112
	Bibliografía.....	115
	ANEXOS.....	117
	ANEXO A: Código de Automatización del Pipeline de Ingesta y Reglas Jerárquicas del SIEM	117
	A.1 Script de Ingesta y Normalización Semántica (process_all_datasets_v3.py).....	117
	A.2 Configuración de Reglas Jerárquicas en Wazuh (local_rules.xml).....	119
	ANEXO B: Matriz de Auditoría Empírica de Telemetría y Alertas del SOC ($n=137$).....	121
	ANEXO C: Catálogo Ontológico STIX 2.1 y Parametrización <i>FRSN</i> en OpenCTI.....	123
	ANEXO D: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™.....	125
	ANEXO E: Fichas Técnicas de Datasets Experimentales y Fuentes de Ciberinteligencia.....	128
	E.1 Repositorios Públicos de Telemetría Experimental.....	128
	1. Mordor Project (Open Threat Research):.....	128

E.2 Fuentes de Ciberinteligencia Táctica.....	129
ANEXO F: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)	131
ANEXO G: Instrumentos de Recolección de Datos (Actividad 2.1).....	133
G.1 Instrumento 1: Plataforma de Orquestación OpenCTI, Mapeadores CSV (CSV Mappers) y Ficha de Ponderación CTI.....	135
G.2 Instrumento 2: Estándares Ontológicos (STIX 2.1), Protocolos TAXII 2.1 y Módulo de Certificación Zero Trust.....	136
G.3 Instrumento 3: Matrices Relacionales Taxonómicas (MITRE ATT&CK®, Attack Flow y MITRE D3FEND™ v1.4).....	138
G.4 Instrumento 4: Consola de Correlación de Eventos (SIEM).....	140
G.5 Instrumento 5: Plantilla Automatizada de Extracción de Métricas (Scripts Python) y Protocolo de Benchmarking.....	141

TABLA DE ILUSTRACIONES

Tabla 1: Matriz Metodológica de Alineación entre Título, Objetivos y Variables del Framework	37
Tabla 2: Matriz de Operacionalización de Variables Independientes y Dependiente del Framework.....	41
Tabla 3: Distribución Estratificada de la Muestra Auditada según Tácticas y Técnicas MITRE ATT&CK® (n = 137).....	49
Tabla 4: Matriz del Modelo de Amenazas del Framework Unificado bajo Metodología STRIDE	56
Tabla 5: Parametrización y Ponderación del Factor de Riesgo de Seguridad Nacional (FR_SN) 66	
Tabla 6: Evaluación Comparativa de Rendimiento en el SOC (Muestra n = 137).....	68
Tabla 7: Métricas Estructurales y Topológicas del Grafo de Conocimiento STIX 2.1 (Caso FamousSparrow).....	72
Tabla 8: Matriz de Correspondencia Táctica Defensiva (MITRE ATT&CK® vs. MITRE D3FEND™).....	75
Tabla 9: Tabla de Contingencia Pareada para Clasificación Diagnóstica (n = 137).....	77
Tabla 10: Prueba Inferencial de Wilcoxon para Tiempos de Detección (MTTD) y Prescripción (MTTR) (n = 137).....	79
Tabla 11: Evaluación de Ablación Secuencial de Componentes del Framework.....	80
Tabla 12: Contraste Metodológico frente a Modelos del Estado del Arte.....	82
Tabla 13: Matriz de Sistematización, Trazabilidad y Control de Congruencia Interna de la Tesis	89
Tabla 14: Playbook Operativo de Mitigación Táctica según Técnica Ofensiva y Contramedida D3FEND™.....	104
Tabla 15: Métricas de Control, Límites Aceptables y Herramientas de Evaluación Operacional del Framework.....	105
Tabla 16: Cronograma de Implantación y Transferencia Técnica del Framework en el SOC....	106
Tabla 17: Presupuesto Estimado de Implementación del Framework (En Dólares Americanos, USD).....	108
Tabla 18: Estructura de la Muestra Auditada (Extracto de Muestra de 5 Registros Representativos).....	120
Tabla 19: Fichas de caracterización ontológica de los ocho actores de amenazas modelados en	

OpenCTI bajo el estándar internacional STIX 2.1.....	122
Tabla 20: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™	124
Tabla 21: Matriz Resumen de Datasets Experimentales y Fuentes de Ciberinteligencia.....	128
Tabla 22: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)	130
Tabla 23: Matriz de Alineación Metodológica: Objetivos, Variables e Instrumentos de Recolección.....	132
Tabla 24: Ficha Técnica de Parámetros CTI y Mapeador CSV para el Factor de Riesgo Nacional (FR_SN).....	134
Tabla 25: Mapeo Relacional Ofensivo-Defensivo basado en MITRE Attack Flow, ATT&CK® y D3FEND™.....	138
Tabla 26: Ficha de Registro de la Cámara de Observación (SIEM Log Audit) para la Muestra Auditada (n = 137).....	139

CAPÍTULO I. PLANTEAMIENTO DE LA INVESTIGACIÓN

1.1 INTRODUCCIÓN

El impacto global de la gestión de la ciberseguridad obliga a redirigir la mirada hacia el contexto local, donde las estrategias de defensa deben alinearse con las amenazas específicas y el entorno operativo en el que se desarrollan. En un panorama donde los incidentes de ransomware y las interrupciones a la Infraestructura Crítica Nacional (ICN) y los servicios esenciales van en aumento, ha quedado en evidencia que las defensas perimetrales estáticas son insuficientes. Si bien los Centros de Operaciones de Seguridad (SOC) buscan evolucionar hacia posturas proactivas mediante el consumo de Inteligencia de Amenazas Cibernéticas (CTI), se enfrentan a un desafío paralizante: la saturación y fragmentación de los reportes globales, un fenómeno documentado como la "cámara de eco" de la inteligencia de amenazas.

En el contexto hondureño, las organizaciones operan con recursos y presupuestos de ciberseguridad finitos, haciendo que su evaluación de actores de amenaza y enfoque de gestión de los insumos que estos puedan brindar a través de las capas de ciberseguridad y los diferentes eventos no estén siendo enfocados al contexto local y sí a enfoques globales, lo cual infiere en evaluaciones de riesgos sesgadas y posibilidades de impacto no acorde con la explotabilidad que actores de amenaza estén ejecutando. Sumado a esto, los modelos teóricos de evaluación de riesgo apoyados en el marco MITRE ATT&CK suelen fracasar en implementaciones reales al asumir un entorno con datos de auditoría perfectos. La realidad técnica de los SOC locales se caracteriza por la opacidad, la incompatibilidad de formatos de logs y un alto nivel de ruido en los eventos del sistema. Sin una correlación temporal adecuada y una limpieza previa, la inteligencia ingerida pierde su valor procesable.

Para resolver esta brecha, esta investigación propone una Metodología de Inteligencia de Amenazas (CTI) basada en MITRE ATT&CK y Gobernanza de Datos para la Priorización de Actores de Amenaza en Honduras. La arquitectura preanalítica se estructura en tres capas: 1) Gobernanza de logs en origen (NIST SP 800-207), 2) Ingesta en OpenCTI en formato STIX 2.1 / TAXII 2.1 integrando la telemetría de Group-IB Threat Intelligence y fuentes Estado/Nación (CISA/FBI) mediante un Factor de Riesgo Único de Seguridad Nacional ($\$FR_{\{\text{SN}\}}\$$), y 3) Secuenciación visual con MITRE Attack Flow y recomendaciones defensivas en MITRE D3FEND™. Al fusionar modelos cuantitativos de riesgo con estrategias de normalización eficiente de registros en tiempo real, este trabajo establece un puente entre la inteligencia cruda y la detección operativa. Este enfoque permite a las organizaciones optimizar sus esfuerzos, enfocando sus capacidades de defensa exclusivamente en los adversarios que representan un peligro inminente y comprobado para la región.

1.2 ANTECEDENTES DEL PROBLEMA

La gestión analítica de la ciberseguridad en entornos operativos contemporáneos se enfrenta a una asimetría estructural entre la masividad de datos recolectados y la capacidad de respuesta táctica de los Centros de Operaciones de Seguridad (SOC). Históricamente, las organizaciones han priorizado el almacenamiento indiscriminado de registros lógicos (logs) bajo premisas perimetrales reactivas. Sin embargo, este enfoque induce a un colapso de capacidades conocido como fatiga de alertas. De acuerdo con las evidencias empíricas recolectadas por (Georgiadou et al., 2021), la proliferación de eventos anómalos benignos no correlacionados satura las pantallas de los analistas, lo cual degrada los tiempos de contención operativa y abre vectores críticos que facilitan movimientos laterales sofisticados.

El problema sistémico se agrava al evaluar el aprovisionamiento de Inteligencia de

Ciberamenazas (CTI). Las plataformas analíticas convencionales ingieren flujos de datos comerciales globales provistos de forma genérica por los fabricantes. Tal como demuestran cuantitativamente (Suarez-Roman et al., 2026), el ecosistema actual de reportes de amenazas padece un severo efecto de cámara de eco (Echo Chamber Effect), caracterizado por la fragmentación, el solapamiento de indicadores atómicos y un profundo sesgo comercial que prioriza las dinámicas de ataques materializados en potencias industrializadas. Al contrastar este sesgo con el diagnóstico regional de (Pavón et al., 2022) sobre la brecha tecnológica y la disparidad de madurez en ciberdefensa de las economías latinoamericanas, se vuelve lógicamente imperativa la transición hacia un modelo metodológico capaz de calibrar el cálculo de riesgos probabilísticos en función del entorno geopolítico local, incorporando la telemetría regional de Group-IB y fuentes gubernamentales (CISA/FBI). El estado del arte analizado por (Yang et al., s. f.) señala que el modelado dinámico de Tácticas, Técnicas y Procedimientos (TTPs) fundamentado en marcos como MITRE ATT&CK es la ruta científica para neutralizar el comportamiento del adversario; no obstante, su viabilidad predictiva está intrínsecamente supuesta sobre la existencia de fuentes de datos puras, íntegras y normalizadas en su origen, integrando herramientas de representación secuencial como MITRE Attack Flow y D3FEND™.

1.3 DEFINICIÓN DEL PROBLEMA

1.3.1 ENUNCIADO DEL PROBLEMA

La ausencia de un marco metodológico estandarizado que unifique el modelado dinámico y cuantitativo de Inteligencia de Ciberamenazas (CTI) adaptado al entorno geopolítico local —alimentado por Group-IB y conectores CISA/FBI en formato STIX 2.1/TAXII 2.1 con un Factor de Riesgo Único ($F R_{SN}$) —, con pipelines automatizados de

Gobernanza de Datos que certifiquen y auditen la calidad de la telemetría en origen bajo principios Zero Trust, genera una persistente saturación analítica por falsos positivos y fatiga de alertas en los Centros de Operaciones de Seguridad (SOC) de las organizaciones en Honduras, lo cual degrada la precisión operativa de los motores de correlación, propicia una severa ceguera ante movimientos laterales de Amenazas Persistentes Avanzadas (APT) y expone de forma crítica e indefensa a las infraestructuras estratégicas, al cumplimiento normativo (Artículo 21 de la Resolución GE No. 342/2018 de la CNBS) y sectores financieros del entorno nacional frente a incidentes no contenidos de ciberdefensa.

1.3.2 FORMULACIÓN DEL PROBLEMA

¿De qué manera el diseño de un framework metodológico que integre la Inteligencia de Amenazas basada en MITRE ATT&CK, gobernanza de datos Zero Trust y análisis geopolítico local permite al SOC priorizar de forma proactiva a los actores de amenazas persistentes avanzadas y vectores críticos dirigidos contra las organizaciones de infraestructura crítica en Honduras?

1.3.3 PREGUNTAS DE INVESTIGACIÓN

- ¿Cómo se pueden adaptar cuantitativamente las ecuaciones de probabilidad de ocurrencia geopolítica regional ($\$LO = II + RI + 0.2\$$) de Ahmed et al. (2022) al perfil de los adversarios activos en Honduras?

- ¿Qué componentes de control técnico debe incluir un framework de gobernanza de datos para certificar y normalizar semánticamente las fuentes de logs en origen, mitigando el ruido analítico en el SIEM?
- ¿De qué forma el modelado de grafos de ataque basados en la dimensión de "Access and Trust" de Georgiadou et al. (2021) permite predecir los movimientos laterales tácticos ante la ejecución de técnicas de Controls Override?
- ¿En qué medida la integración sinérgica del pipeline de gobernanza en origen, la ciberinteligencia contextualizada para Honduras y el mapeo defensivo prescriptivo reduce la tasa de falsos positivos y optimiza los tiempos medios de detección (*MTTD*) y prescripción de respuesta (*MTTR*) en la consola del SOC?

1.4 OBJETIVOS DEL PROYECTO

- **Objetivo General:**
 - Desarrollar una metodología analítica de Inteligencia de Amenazas (CTI) basada en MITRE ATT&CK, Gobernanza de Datos y Seguridad Nacional para optimizar las capacidades de priorización proactiva de **actores de amenazas persistentes y campañas dirigidas** dentro de los Centros de Operaciones de Seguridad (SOC) en organizaciones de infraestructura crítica de Honduras.
- **Objetivos Específicos:**
 - Adaptar y calibrar cuantitativamente el modelo matemático de probabilidad de ocurrencia geopolítica ($LO = II + RI + 0.2$) propuesto por Ahmed et al. (2022) al

perfil táctico y motivacional de los adversarios y grupos de ciberamenazas relevantes para la seguridad nacional y la infraestructura crítica activa en Honduras.

- Diseñar un framework técnico de gobernanza, normalización semántica y certificación de calidad para fuentes de logs en origen, mitigando el ruido analítico antes de la fase de correlación de eventos en el SIEM.
- Modelar las trayectorias de riesgo y movimientos laterales mediante la construcción de Grafos de Ataque dinámicos, evaluando la resistencia de los componentes de control de acceso exigidos por la norma NIST SP 800-207 frente a tácticas de evasión avanzada (*Controls Override*).
- Evaluar el desempeño del framework metodológico unificado mediante escenarios experimentales controlados de telemetría de ataques dirigidos (incluyendo vectores de compromiso inicial, explotación, movimiento lateral y ransomware) para cuantificar empíricamente la reducción del ruido analítico y la optimización de los tiempos de detección y respuesta en el SOC.

1.5 JUSTIFICACIÓN

La presente investigación se justifica de manera multidimensional para responder a los retos críticos de seguridad informática y gobernanza que enfrentan las organizaciones que sostienen los servicios esenciales en Honduras.

Desde una justificación científica, este estudio aborda una brecha de conocimiento crítica detectada en la literatura internacional (Ahmed et al., 2022; Jiang et al., 2025). Los modelos matemáticos predictivos de amenazas globales asumen de forma idealista que los datos corporativos de entrada son homogéneos y perfectos. Esta investigación rompe ese paradigma y

genera nuevo conocimiento al demostrar teórica y experimentalmente que la precisión analítica de las fórmulas de riesgo de ciberinteligencia depende de un marco previo de gobernanza que certifique el no repudio y la integridad de los logs en la fuente de origen.

En el ámbito de la justificación tecnológica, la metodología propone una innovación concreta: un framework de ingeniería de características (feature engineering) y normalización semántica automatizada para registros de auditoría. Esta herramienta dota a las infraestructuras de monitoreo tradicionales (SIEM) de capacidades avanzadas de filtrado de ruido y traducción algorítmica automatizada hacia técnicas de MITRE ATT&CK, permitiendo una automatización simétrica de la defensa.

Socialmente, la justificación social se fundamenta en la protección directa del Compromiso al Bienestar Humano (CHW) de la población hondureña. Sectores como energía, telecomunicaciones, banca y salud representan la espina dorsal del país; un ataque de Ransomware exitoso en estas infraestructuras no solo compromete datos confidenciales, sino que interrumpe la provisión de servicios públicos vitales. Esta tesis dota a la nación de un modelo metodológico soberano y geográficamente acotado para salvaguardar la estabilidad social.

Finalmente, la justificación económica responde a la necesidad de optimizar los recursos financieros en entornos con presupuestos restrictivos. Las organizaciones hondureñas no poseen el capital para competir contra las masivas inversiones tecnológicas de países desarrollados. Priorizar científicamente a los atacantes reales de la región permite al SOC enfocar sus inversiones de respuesta y configuraciones analíticas exclusivamente en las amenazas de mayor probabilidad de impacto, disminuyendo drásticamente las pérdidas financieras directas (DFL) por paradas operativas no programadas y multas legales (LF), maximizando el retorno de inversión en ciberdefensa.

Para validar científicamente la viabilidad de la investigación y responder a las exigencias formalistas de posgrado, el sistema defensivo propuesto se define formalmente bajo los siguientes supuestos analíticos e invariantes de ingeniería:

Definición Formal del Sistema: Sea D el flujo total de telemetría y eventos lógicos ingerido por el Centro de Operaciones de Seguridad (SOC), tal que $D = D_p \cup D_r$, donde D_p representa el conjunto de datos semánticamente puros y conformes, y D_r representa el subconjunto de ruido estructural, registros degradados o alterados por técnicas de evasión de bitácoras (*Controls Override*).

Para formalizar las relaciones causales que guían la investigación y responder al rigor metodológico de posgrado, el sistema defensivo propuesto se fundamenta en las siguientes proposiciones teóricas e hipótesis de trabajo:

Definición Formal del Sistema: Sea D el flujo total de telemetría y eventos lógicos ingerido por el Centro de Operaciones de Seguridad (SOC), tal que $D = D_p \cup D_r$, donde D_p representa el conjunto de datos sintácticamente puros y conformes con el esquema requerido, y D_r representa el subconjunto de ruido estructural, registros degradados, campos nulos o telemetría alterada por técnicas de evasión de bitácoras (*Controls Override*).

Proposición Teórica Operativa 1 (P1 - Eficiencia Preanalítica): Si el motor de correlación del SIEM procesa un flujo de datos donde el coeficiente de ruido en origen se minimiza ($D_r \rightarrow \emptyset$) mediante un pipeline automatizado de gobernanza que valida la integridad de los campos antes de la indexación (Capa 1), y la priorización táctica se restringe algorítmicamente mediante el Factor de Riesgo Nacional ($F R_{SN}$) derivado de ciberinteligencia regional (Capa 2), entonces la sobrecarga analítica por eventos no prioritarios se reduce de manera sustancial frente a un modelo de ingesta pasiva tradicional.

Hipótesis de Investigación (H1): La implementación sinérgica del framework unificado (pipeline de gobernanza Zero Trust, priorización geopolítica $F R_{SN}$ y mapeo prescriptivo MITRE D3FEND) produce una reducción estadísticamente significativa en la tasa de falsos positivos (TFP) y una disminución en los tiempos medios de detección ($MTTD$) y prescripción de respuesta ($MTTR$) frente a una arquitectura de ingesta pasiva convencional.

Hipótesis Nula (H0): La implementación del framework unificado no produce diferencias estadísticamente significativas en la tasa de falsos positivos (TFP) ni en los tiempos operativos de detección y respuesta en comparación con una arquitectura de ingesta pasiva tradicional.

1.6 CONTRIBUCIONES Y ALCANCES

Alcance del Proyecto: La investigación circunscribe su alcance técnico y operativo a la ciberdefensa de la Infraestructura Crítica Nacional (ICN) de la República de Honduras, abarcando sectores estratégicos como el financiero, energía, telecomunicaciones y servicios esenciales del Estado. En el plano tecnológico y de Ciberinteligencia de Amenazas (CTI), el alcance contempla:

1. La ingesta de telemetría regionalizada a través de la plataforma Group-IB Threat Intelligence y alimentadores oficiales Estado/Nación (CISA KEV y FBI InfraGard/FLASH) bajo el estándar STIX 2.1 / TAXII 2.1 centralizados en la plataforma OpenCTI.
2. El cálculo de priorización mediante un Factor de Riesgo Único de Seguridad Nacional ($F R_{SN}$), adaptado para Honduras a partir del modelo probabilístico de riesgo geopolítico.
3. La secuenciación temporal y visual de ataques mediante MITRE Attack Flow y la recomendación de contramedidas técnicas informativas mapeadas en el grafo MITRE D3FEND™.

4. La automatización de controles sintácticos para el cumplimiento de las pistas de auditoría exigidas por el Artículo 21 de la Resolución GE No. 342/2018 de la CNBS.

Alcance Experimental: La validación metodológica se circunscribe a un entorno de simulación controlado y aislado (Sandbox en Docker), fundamentado en la ingesta, normalización y validación analítica de casos de estudio dirigidos de actores APT (como FamousSparrow y campañas asociadas), evaluando la precisión en la atribución, el filtrado de ruido y la optimización de los tiempos de detección y respuesta en el SOC.

1.7 LIMITACIONES

Con el propósito de delimitar el área de estudio y garantizar la viabilidad del protocolo, se establecen las siguientes restricciones del proyecto:

- **Entornos productivos reales:** La metodología y el prototipo de software desarrollado no serán implementados ni testeados en infraestructuras analíticas en producción ni en redes vivas de ninguna empresa u organización activa en el país, debido a restricciones estrictas de confidencialidad y para mitigar riesgos de continuidad de negocio.
- **Solución comercial empaquetada:** La investigación no contempla el desarrollo de un producto de software comercial, un SIEM propietario o una plataforma empaquetada lista para el mercado.
- **Vectores de ataque excluidos:** El modelado y la evaluación experimental se centran en campañas dirigidas de adversarios persistentes y vectores de penetración avanzada (explotación de servicios expuestos, inyección de scripts ofuscados, abuso de credenciales

locales y despliegue de cargas de ransomware), excluyendo del alcance ataques distribuidos de denegación de servicio volumétrico (DDoS) a nivel de infraestructura de capa de red y campañas de spam masivo no focalizado.

CAPÍTULO II. MARCO TEÓRICO

2.1. ANÁLISIS DE LA SITUACIÓN ACTUAL.

La protección de las infraestructuras críticas en Honduras —que abarcan sectores vitales como energía, telecomunicaciones, salud y el sistema financiero— se encuentra en una encrucijada operativa crítica. La gestión de ciberseguridad de los entornos locales opera predominantemente bajo esquemas tradicionales de naturaleza reactiva, lo que limita su capacidad para anticipar intrusiones complejas ejercidas por actores de amenaza a través de las diferentes Tácticas, Técnicas y Procedimientos (TTPs) que estos implementan. De acuerdo con las evaluaciones macro sobre la madurez de la ciberseguridad en América Latina, las capacidades de defensa e intercambio de inteligencia táctica muestran brechas estructurales profundas debido a restricciones de presupuesto y a la escasez de analistas especializados (Pavón et al., 2022)

Esta situación se ve agravada por la evolución tecnológica y la gestión de empresas en el entorno nacional, lo cual ha atraído la presencia de actores hostiles avanzados cuyas campañas dirigidas demuestran que las defensas estáticas perimetrales ya no son capaces de contener movimientos laterales complejos. Como demuestran empíricamente (Georgiadou et al., 2021), la proliferación de eventos anómalos benignos no correlacionados satura las capacidades analíticas de los equipos de respuesta (IT/OT), induciendo a una severa fatiga de alertas que dilata los tiempos de mitigación y vulnera la disponibilidad de los servicios esenciales.

Ante la falta de un marco soberano de priorización, las organizaciones locales importan flujos genéricos de Inteligencia de Amenazas (CTI) comerciales que saturan las consolas de monitoreo con Indicadores de Compromiso (IoCs) desconectados del contexto nacional (Suarez-Roman et al., 2026). El resultado es un Centro de Operaciones de Seguridad (SOC) con casos de uso no acordes con una gestión analítica de las TTPs u operación del actor, generando un procesamiento ineficiente y una capacidad sesgada de entender y reaccionar ante la presencia de un incidente de ciberdefensa en el entorno real.

2.2. CONCEPTUALIZACIÓN

Para establecer el soporte semántico e interpretativo de esta investigación, la construcción del marco conceptual aborda la evolución dinámica y el consenso actual de los constructos centrales, superando la estructura de un glosario pasivo de términos.

El concepto de Inteligencia de Amenazas Cibernéticas (CTI) Táctica ha evolucionado significativamente desde la recolección estática y reactiva de firmas atómicas (como direcciones IP o hashes de malware) hacia el modelado conductual abstracto del adversario. Bajo la perspectiva actual de (Villalón Huerta, 2023) y la revisión sistemática, el consenso de la comunidad científica dictamina que la ciberinteligencia táctica debe fundamentarse en la categorización de Tácticas, Técnicas y Procedimientos (TTPs) a través de marcos estructurados como MITRE ATT&CK®. Esta dimensión trasciende los indicadores atómicos tradicionales al concentrarse en capturar las pautas repetibles de comportamiento del atacante, permitiendo interceptar intrusiones avanzadas de forma proactiva con independencia de las herramientas de software mutables que use el adversario.

Para operativizar esta distinción analítica, la investigación se fundamenta en

(Davidjbianco, 2013). Este modelo epistemológico categoriza los indicadores utilizados en ciberdefensa según la dificultad y el costo relativo que representa para un adversario evadirlos cuando son bloqueados. En la base de la pirámide se encuentran los Indicadores de Compromiso (IoC) tradicionales y atómicos (valores hash, direcciones IP y nombres de dominio), los cuales son triviales de alterar mediante técnicas de polimorfismo o infraestructura desechable, generando además una alta tasa de falsos positivos en los sistemas de monitoreo. Por el contrario, este trabajo traslada el esfuerzo defensivo hacia la cúspide de la pirámide: los Indicadores de Ataque (IoA), representados por las Tácticas, Técnicas y Procedimientos (TTPs) conductuales de MITRE ATT&CK®. La identificación basada en IoAs intercepta la intencionalidad operativa y la secuencia de ejecución del intruso (independientemente del binario o la IP utilizada), forzando al atacante a rediseñar por completo su metodología de intrusión ante la respuesta defensiva.

De igual forma, la Gobernanza de Datos de Auditoría ha transitado desde un enfoque archivístico de cumplimiento normativo pasivo hacia un control de calidad técnico preventivo dentro de la arquitectura de seguridad. En la actualidad, se define como el conjunto coordinado de políticas, validaciones sintácticas y pipelines algorítmicos aplicados directamente en el origen del dato. Su propósito es certificar la calidad, integridad estructural, completitud y el no repudio de los registros de actividad (logs) emitidos por dispositivos heterogéneos antes de su ingesta en los motores analíticos, neutralizando el ruido sintáctico que propicia desviaciones en el diagnóstico defensivo.

Por su parte, el fenómeno denominado Fatiga de Alertas del SOC se conceptualiza científicamente como la degradación de la capacidad de atención y respuesta cognitiva del analista debido a la sobreexposición a volúmenes masivos de alertas de seguridad redundantes o

falsos positivos. Su origen radica en el diseño de reglas de correlación y casos de uso basados en umbrales estáticos y firmas aisladas, omitiendo el contexto de un vector de ataque multidimensional, la secuencia conductual de una TTP y el perfil específico del actor que dirige la campaña de intrusión.

Finalmente, las variables de Entorno Geopolítico, Vectores de Ataque y el Nivel de Madurez de Ciberseguridad Local constituyen constructos interdependientes que determinan la probabilidad real de que un sector estratégico sea seleccionado como objetivo prioritario por un adversario. La literatura científica moderna establece que el riesgo no es una probabilidad abstracta global, sino un cálculo condicionado por dinámicas socioeconómicas territoriales, motivaciones de extorsión financiera regionales y el grado de capacidad regulatoria y técnica que posee un país específico para identificar, proteger, detectar y recuperar sus activos esenciales frente a incidentes a gran escala.

2.3. TEORÍAS DE SUSTENTO

2.3.1. BASES TEORICAS

El núcleo metodológico y la innovación profesionalizante de la presente propuesta unifican e interconectan marcos teóricos complementarios estudiados a lo largo de la maestría, aplicándolos articuladamente a una realidad concreta del entorno nacional: la optimización y ciberdefensa de las infraestructuras críticas y sectores estratégicos de Honduras.

En primera instancia, se adopta el Modelo de Riesgo Cuantitativo Orientado al Adversario de (Ahmed et al., 2022). Esta formulación probabilística sustituye las matrices de riesgo cualitativas subjetivas por ecuaciones deterministas asociadas a grafos de ataque, donde la

probabilidad de ocurrencia de una amenaza (*LO, Likelihood of Occurrence*) se modela como una función del Interés de la Industria (*II*) y el Interés Regional (*RI*), incorporando una constante empírica de base para entornos corporativos:

$$LO = II + RI + 0.2$$

Esta investigación adapta dicha formalización para el contexto de Honduras, calibrando adaptativamente los parámetros *II* y *RI* en función de la telemetría histórica y los reportes de inteligencia estratégica orientados a sectores como Banca, Energía y Gobierno.

La segunda base teórica es la Arquitectura Zero Trust (ZTA), normada internacionalmente en la publicación especial (Rose et al., 2020). Este paradigma elimina la noción de confianza implícita en redes internas y postula el principio de verificación continua y explícita de cada sujeto, activo y flujo de datos. Aunque NIST SP 800-207 no constituye una norma de formato de registros en sí misma, el framework propuesto adopta su filosofía de verificación continua aplicándola a las etapas preanalíticas del dato: ningún registro de telemetría es transferido al motor de correlación del SIEM sin haber certificado previamente su integridad sintáctica, completitud y autenticidad en origen.

Finalmente, se incorpora la dimensión analítica de Cultura y Resistencia de Controles de (Georgiadou et al., 2021). Este trabajo vincula la madurez de la seguridad con la taxonomía MITRE ATT&CK®, analizando cómo la falta de controles estrictos de autenticación y confianza facilita la explotación de credenciales y accesos legítimos. En nuestro marco, esta teoría sustenta la modelación de escenarios donde el adversario emplea técnicas de evasión como *Controls Override* (abuso o degradación de privilegios de auditoría) para ejecutar movimientos laterales sin activar alertas perimetrales básicas.

Articulación Coherente de las Metodologías: La pertinencia de articular estos enfoques radica en la codependencia estricta del procesamiento de datos. Los modelos predictivos y las reglas de correlación de ciberinteligencia se degradan drásticamente ante datos ruidosos o incompletos (*Garbage In, Garbage Out*). Al integrar los principios de verificación continua de la norma NIST SP 800-207 en el pipeline de telemetría, se alimenta al motor de correlación con registros sintácticamente certificados, permitiendo que la priorización geopolítica contextualizada aísle las amenazas prioritarias y reduzca sustancialmente la fatiga analítica en el SOC.

2.3.2. METODOLOGÍAS DESARROLLADAS

En el estado del arte de la ciberdefensa se identifican tres enfoques metodológicos alternativos utilizados en procesos de investigación similares, cuyas limitaciones críticas justifican el desarrollo de esta propuesta unificada:

- **Modelado Estocástico Basado en CVSS:** Enfoque clásico centrado en la severidad intrínseca y estática de las vulnerabilidades informáticas. Su gran limitación metodológica es que asume un entorno defensivo pasivo, ignorando las capacidades dinámicas del adversario, el historial conductual de sus campañas y el contexto geográfico o sectorial específico de la organización evaluada.
- **Mapeo Automatizado mediante Procesamiento de Lenguaje Natural (NLP):** Metodologías de vanguardia emplean modelos de aprendizaje automático e inteligencia artificial para extraer TTPs a partir de reportes de CTI en texto libre crudo. A pesar de su innovación algorítmica, padecen el denominado Supuesto de Ingesta Ideal, pues su precisión analítica decae exponencialmente si las fuentes de telemetría y logs de auditoría originales del SOC

de destino contienen ruido estructural, duplicidades sintácticas o incompatibilidades de formato.

- Gráficos de Conocimiento Defensivo (MITRE D3FEND™): Enfoques orientados a estructurar de manera semántica las contramedidas técnicas de ingeniería defensiva (como análisis de linaje de procesos, inspección de tráfico o aislamiento de red). Aunque organizan de forma sistemática la correspondencia defensiva frente a MITRE ATT&CK®, MITRE advierte que dichas relaciones son de naturaleza inferida y experimental, no equivalencias deterministas cerradas. Asimismo, requieren de un modelo previo de priorización probabilística contextual para determinar qué contramedidas activar primero en entornos con recursos operativos limitados.

Este análisis crítico del estado del arte revela la Brecha de Investigación (Research Gap): la ausencia de un marco metodológico híbrido que unifique las ecuaciones predictivas de riesgo geopolítico (CTI táctica) con pipelines estrictos de gobernanza de datos para la normalización, validación semántica y limpieza de registros lógicos directamente en la fuente de origen dentro de los Centros de Operaciones de Seguridad de economías emergentes.

2.3.3. INSTRUMENTOS UTILIZADOS

La operativización de los modelos y metodologías analizados en la literatura científica previa evidencia el empleo de instrumentos técnicos específicos que sirven como marcos de referencia instrumental para la presente investigación.

1. Matrices de Comportamiento Adversario MITRE ATT&CK®: Empleando de forma

unificada las matrices conductuales de Enterprise e ICS (Sistemas de Control Industrial) como un instrumento taxonómico granular para mapear las tácticas del atacante en entornos híbridos y rastrear la progresión de movimientos laterales.

2. Algoritmos de Normalización en Tiempo Real de Gerhards (2016): Utilizando estructuras de clasificación basadas en Grafos Acíclicos Dirigidos (PDAG) en lugar de expresiones regulares tradicionales. Este instrumento de software es el que permite procesar masivamente mensajes de logs heterogéneos bajo condiciones de cargas operativas masivas sin introducir latencia o retrasos en el motor de ingesta del SIEM.
3. Instrumentos de Control Temporal y Enrutamiento: Mediante motores de enrutamiento avanzado (syslog-ng) e instrumentos de monitoreo temporal de eventos basados en la inyección de mensajes tipo heartbeat (latidos de estado temporales) validados en los principios de motores como VTEC de AMD o PROID. Estos instrumentos de software permiten aislar el ruido de los eventos benignos del sistema y alertar de forma automatizada sobre la interrupción u opacidad de los flujos de datos debida a técnicas de evasión del intruso.

2.4. MARCO LEGAL

El desarrollo y la futura implementación de la metodología propuesto interactúan directamente con un estricto ecosistema regulatorio y de cumplimiento sectorial (Compliance) aplicable en la República de Honduras, obligando a las organizaciones a transicionar desde auditorías manuales reactivas hacia controles de ingeniería continuos.

2.4.1. MARCO REGULATORIO NACIONAL

Normas para la Gestión del Riesgo Tecnológico de la CNBS (Resolución GE No. 342/2018, Artículo 21): Emitida por la Comisión Nacional de Bancos y Seguros, esta normativa establece las directrices prudenciales de cumplimiento obligatorio para las instituciones del sistema financiero, asegurador y previsional supervisadas en Honduras. El Artículo 21 dictamina de forma mandatoria la generación, mantenimiento y custodia inalterable de pistas de auditoría (*logs*) detalladas que registren los accesos, modificaciones y eventos de seguridad en plataformas y servicios críticos. En los entornos evaluados, la sobrecarga analítica derivada de bitácoras degradadas o incompletas genera zonas de opacidad que pueden conducir al incumplimiento normativo involuntario ante el ente supervisor. El pipeline de gobernanza propuesto contribuye al cumplimiento de las directrices del Artículo 21 al certificar la integridad estructural y trazabilidad temporal de los registros en su punto de origen.

2.4.2. ESTÁNDARES INTERNACIONALES VINCULANTES EN EL ENTORNO NACIONAL

- Estándar de Seguridad de Datos de la Industria de Tarjetas de Pago (*Official PCI Security Standards Council Site - Document*, s. f.): Este marco internacional constituye un estándar técnico-contractual de adopción mandatoria para cualquier organización que procese, almacene o transmita datos de titulares de tarjetas de pago (PCI SSC, 2022). El **Requisito 10** (*Registrar y supervisar todos los accesos a los recursos de red y a los datos de los titulares de tarjetas*) establece en su acápite 10.4.1 la obligación de examinar diariamente los registros de eventos de seguridad en sistemas críticos que manejan información sensible, mientras que el acápite 10.4.2 permite determinar la frecuencia de revisión para el resto de la infraestructura con base en análisis dirigidos de riesgo de la entidad (Targeted

Risk Analysis). La saturación por falsos positivos dificulta la revisión oportuna de estas alertas. El framework propuesto asiste operativamente en el cumplimiento del Requisito 10 al filtrar el ruido estructural antes de la ingesta y estructurar la correlación sobre subgrafos de ataque (Peng & Zhang, s. f.).

- Norma Internacional ISO/IEC 27001:2022 (**Controles A.8.15 y A.8.16**): ISO/IEC 27001:2022 actúa como un estándar internacional ampliamente adoptado en Honduras como requisito en pliegos de contratación pública y marcos de gobernanza institucional. En su Anexo A, el Control A.8.15 (Registro de eventos / *Logging*) exige que los registros que documentan la actividad de los usuarios, excepciones, fallas y eventos de seguridad sean producidos, almacenados, protegidos contra manipulación y analizados periódicamente. Complementariamente, el Control A.8.16 (Actividades de monitoreo / *Monitoring activities*) mandatea la supervisión continua del comportamiento de las redes, sistemas y aplicaciones para detectar posibles incidentes de seguridad. La debilidad en la validación en origen facilita que técnicas de evasión como *Controls Override* corrompan las pistas de auditoría antes de su almacenamiento. El pipeline de gobernanza preanalítico aquí diseñado inspecciona sintácticamente cada log en origen bajo principios Zero Trust, asegurando la no alteración del registro exigida por el Control A.8.15 y optimizando el monitoreo demandado por el Control A.8.16.

CAPÍTULO III. METODOLOGÍA

2.5. CONGRUENCIA METODOLÓGICA

En este capítulo se detalla la ruta operativa y procedimental seguida para diseñar, implementar y evaluar los controles de ingeniería propuestos, justificando científicamente la selección de cada componente técnico bajo el paradigma metodológico de Design Science Research (Hevner & Ram, s. f.). De acuerdo con las exigencias de la investigación aplicada y tecnológica en ciberseguridad, este estudio adopta un enfoque mixto (cuantitativo-cualitativo) con diseño cuasiexperimental de laboratorio. La adopción de este enfoque responde a la necesidad de controlar los márgenes de error y maximizar el grado de confiabilidad de la telemetría procesada en el Centro de Operaciones de Seguridad (SOC). El componente cualitativo legitima el modelado taxonómico, semántico y conductual de los actores de amenaza mediante la identificación de sus Tácticas, Técnicas y Procedimientos (TTPs) en MITRE ATT&CK®, la caracterización en grafos STIX 2.1 en OpenCTI y su correspondencia prescriptiva con MITRE D3FEND™. En contrapartida, el componente cuantitativo es indispensable para parametrizar de forma matemática el riesgo predictivo local mediante la ecuación calibrada del Factor de Riesgo Nacional (FR_N), así como para contrastar inferencialmente el rendimiento de las consolas analíticas (Tasa de Falsos Positivos, MTTD y MTTR) sobre una muestra auditada de eventos de ataque frente a la arquitectura tradicional.

2.5.1. MATRIZ METODOLÓGICA

Para garantizar la consistencia analítica interna de la investigación y satisfacer los estándares del Manual de Fondo, la Tabla 3.1 establece la alineación unívoca entre el título formal,

el objetivo general, los cuatro objetivos específicos y las variables del estudio.

Tabla 1: Matriz Metodológica de Alineación entre Título, Objetivos y Variables del Framework

Título de la investigación	Objetivos de investigación: General	Objetivos de investigación: Específicos	Variables
Framework Unificado de Ciberinteligencia de Amenazas (CTI) basado en MITRE ATT&CK®, Gobernanza de Datos Zero Trust y Seguridad Nacional para la Priorización de Actores de Amenaza en Honduras.	Desarrollar un framework metodológico unificado que integre un pipeline de gobernanza de logs en origen bajo principios Zero Trust, ciberinteligencia contextualizada para Honduras y prescripción defensiva, para optimizar el rendimiento analítico y mitigar el ruido precursor de la fatiga de alertas en los Centros de Operaciones de Seguridad (SOC) de la infraestructura crítica nacional.	O1: Adaptar y calibrar cuantitativamente el modelo probabilístico de riesgo geopolítico ($LO = II + RI + 0.20$) al perfil táctico y motivacional de los adversarios relevantes para la infraestructura crítica y la seguridad nacional en Honduras. O2: Diseñar un pipeline técnico automatizado de gobernanza, normalización semántica y validación sintáctica de datos en origen (NIST SP 800-207) para suprimir el ruido	Variable Independiente (X_1): Mapeo Geopolítico y Priorización en CTI (Variables II, RI y Factor $F R_{SN}$). Variable Independiente (X_2): Nivel de Gobernanza de Datos Zero Trust (Coeficiente de ruido estructural R_{ruido} y validación sintáctica en origen). Variable Independiente (X_3): Mapeo Defensivo Prescriptivo (Taxonomía y técnicas de contramedida en

		estructural en la telemetría antes de su ingreso al SIEM O3: Modelar las trayectorias de intrusión mediante grafos de conocimiento STIX 2.1 y evaluar la correspondencia defensiva prescriptiva hacia el catálogo MITRE D3FEND™ frente a técnicas de evasión avanzada (<i>Controls Override</i>) O4: Evaluar experimentalmente el desempeño del framework unificado en un entorno Sandbox mediante telemetría de ataques dirigidos, contrastando empíricamente la reducción de la tasa de falsos positivos (	MITRE D3FEND™). Variable Independiente (Y): Eficiencia Operativa del SIEM y Mitigación de Ruido Analítico Precursor de la Fatiga de Alertas (Operacionalizada mediante <i>TFP</i>, <i>MTTD</i> y <i>MTTR</i>).
--	--	---	--

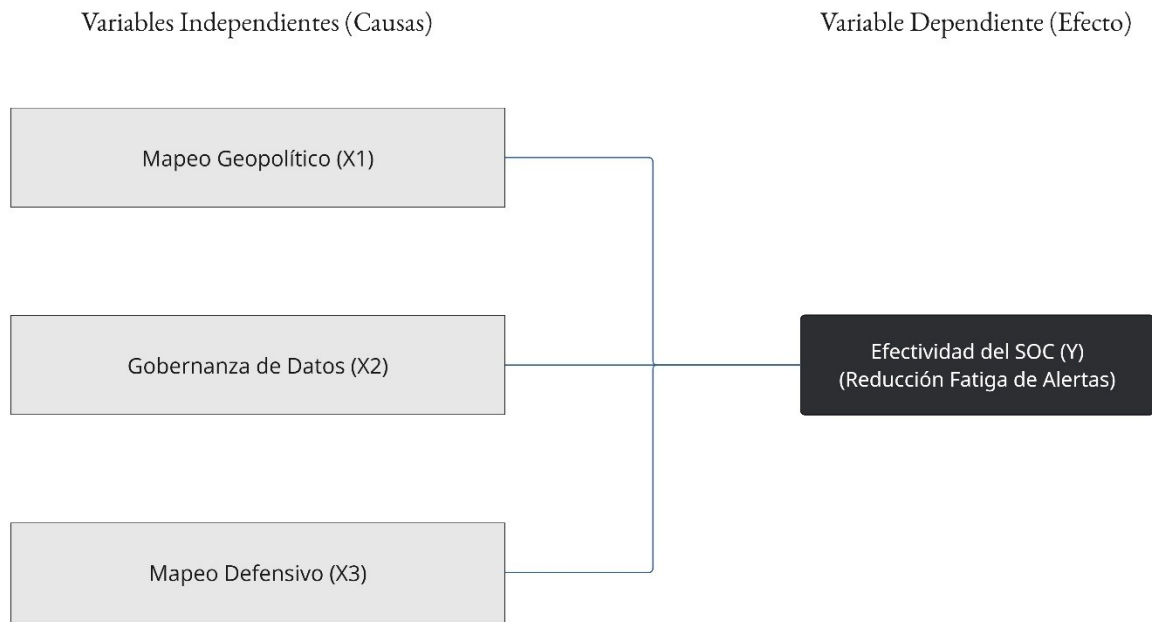
		TFP) y la optimización de los tiempos operativos (<i>MTTD</i> , <i>MTTR</i>).	
--	--	---	--

Nota. Matriz de consistencia interna y operacionalización metodológica de la investigación. CTI = *Cyber Threat Intelligence*; SOC = *Security Operations Center*; II = Interés de Industria; RI = Interés Regional; FR_{SN} = Factor de Riesgo de Seguridad Nacional; TFP = Tasa de Falsos Positivos; *MTTD* = Tiempo Medio de Detección; *MTTR* = Tiempo Medio de Respuesta/Prescripción. Elaboración propia

2.5.2. ESQUEMA DE VARIABLES DE ESTUDIO

En este apartado se expresan las variables del sistema en términos de la relación de causalidad y el vínculo técnico que existe entre ellas. La lógica del framework determina que el comportamiento de la variable dependiente final está condicionado por la manipulación controlada de los tres componentes de ingeniería previos. El argumento causal se establece de la siguiente manera: El mapeo geopolítico de amenazas locales (X_1), coordinado con el nivel de gobernanza y normalización de datos lógicos en la fuente de origen (X_2), aunado con un despliegue de contramedidas tácticas basadas en MITRE D3FEND™ (X_3), determina el nivel de efectividad operativa y la reducción de la fatiga de alertas (Y) en los Centros de Operaciones de Seguridad (SOC) en Honduras. Para la representación visual de este vínculo multivariado en el documento final, se utiliza el siguiente diagrama sagital de relaciones lógicas:

Ilustración 1: Diagrama Sagital de Relación Causal entre las Variables Independientes y Dependiente del Framework



Nota. Estructura multivariada de causalidad del estudio donde X_1 representa el Mapeo Geopolítico, X_2 la Gobernanza de Datos y X_3 el Mapeo Defensivo, convergiendo en la variable de respuesta Y (Efectividad del SOC y reducción de la fatiga analítica). SOC = Centro de Operaciones de Seguridad (Security Operations Center). Elaboración propia.

2.5.3. OPERACIONALIZACIÓN DE LAS VARIABLES

En este apartado se estructuran y desglosan las variables que componen la arquitectura causal del framework, definiendo de manera unívoca sus alcances teóricos y los procedimientos experimentales para su medición cuantitativa. Para cada variable del sistema se delimita su definición conceptual —sustentada en el consenso científico de las bases de conocimiento y estándares adoptados— y su definición operacional, la cual describe las ecuaciones algebraicas,

métricas informáticas y metodologías de extracción automatizada en el laboratorio controlado. Asimismo, se identifican las dimensiones teóricas que articulan cada variable y los indicadores específicos sujetos a contraste estadístico.

Tabla 2: Matriz de Operacionalización de Variables Independientes y Dependiente del Framework

Variable	Definición Conceptual	Definición Operacional	Dimensiones	Ítems/ Indicadores
Mapeo Geopolítico y Priorización en CTI (X_1)	Dimensión analítica orientada a contextualizar la Inteligencia de Amenazas Cibernéticas (CTI) Táctica mediante la parametrización de la afinidad regional y sectorial de un adversario humano.	Cálculo matemático determinista de la Probabilidad de Ocurrencia (LO) mediante la agregación de pesos discretos asignados a la industria y la localización geográfica del objetivo, expresado por la ecuación de (Ahmed et al., 2022): $LO = II + R1 + 0.2$	Contexto Geográfico Nacional. Afinidad Sectorial Operativa.	Puntuación de Interés Regional para Honduras ($RI \in [0.0, 1.0]$). Puntuación de Interés de Industria para infraestructura crítica ($II \in [0.0, 1.0]$). Clasificación categórica de criticidad ($F R_{SN} \geq 0.95 \rightarrow CRI$).
Nivel de Gobernanza de Datos Zero Trust	Pipeline preanalítico diseñado bajo el principio de	Aplicación algorítmica en Python que purifica el flujo total de telemetría ($D = D_p \cup D_r$), aislando el	Normalización Estructural del Log.	Coeficiente de ruido residual en origen ($R_{ruido} \rightarrow 0.00$).

(X ₂)	verificación continua de la Arquitectura Zero Trust (NIST SP 800-207) para certificar la integridad semántica, normalización sintáctica y calidad de logs en origen.	subconjunto de ruido estructural (D_r) y calculando el coeficiente de ruido residual: $R_{ruido} = \frac{N_{corruptos}}{N_{total}}$	Certificación de Pistas de Auditoría (Art. 21 CNBS).	Porcentaje de logs validados bajo esquema estricto (ISO 8601, EventID, CommandLine).
Mapeo Defensivo Prescriptivo (X ₃)	Vinculación y estructuración de contramedidas técnicas de ingeniería defensiva basadas en el grafo relacional MITRE D3FEND™ v1.4 para orientar la respuesta frente a TTPs ofensivas	Identificación y traducción automática de la alerta conductual detectada frente al catálogo prescriptivo de MITRE D3FEND™, asociando en la cabecera de la regla SIEM la técnica defensiva orientativa aplicable (relación inferida/experimental).	Orquestación Prescriptiva. Correspondencia Semántica ATT&CK → D3FEND.	Identificador unívoco del control defensivo oficial (e.g., D3-ITF, D3-SEA, D3-MFA, D3-NI) Tasa de cobertura prescriptiva por técnica de ataque evaluada.

	específicas.			
Eficiencia Operativa del SIEM y Supresión de Ruido Analítico (Y)	Capacidad analítica y cuantitativa del Centro de Operaciones de Seguridad (SOC) para optimizar el rendimiento de la consola, suprimiendo falsos positivos precursores de la fatiga de alertas y acelerando la respuesta táctica.	Evaluación multivariable del rendimiento del cluster Wazuh/OpenSearch en el laboratorio sobre $n=137$ registros mediante tres métricas operativas: 1. Tasa de Falsos Positivos (TFP): $TFP = \left(\frac{FP}{FP + TP} \right) \times 100$ 3. Tiempo Medio de Detección (MTTD): $MTTD = \frac{1}{n} \sum_{i=1}^n t_{alerta, i} - t_{ejecución, i}$ 4. Tiempo Medio de Respuesta (MTTR): $MTTR = \frac{1}{m} \sum_{j=1}^m t_{prescripción, j} - t_{alerta, j}$	Precisión Diagnóstica. Latencia Preanalítica de Detección. Agilidad de Prescripción Defensiva.	Tasa de Falsos Positivos (TFP en puntos porcentuales y reducción relativa) Tiempo Medio de Detección ($MTTD$ en segundos). Tiempo Medio de Prescripción de Contramedida en Consola ($MTTR$ en segundos).

Nota. Operacionalización formal de variables bajo el diseño Design Science Research (DSR). CTI

= Cyber Threat Intelligence; LO = Likelihood of Occurrence; II = Interés de Industria; RI = Interés

Regional; FR_SN = Factor de Riesgo de Seguridad Nacional; ZTA = Zero Trust Architecture; TFP = Tasa de Falsos Positivos; FP = Falsos Positivos; TP = Verdaderos Positivos; MTTD = Tiempo Medio de Detección; MTTR = Tiempo Medio de Respuesta/Prescripción (medido hasta la inyección de la recomendación en consola, distinguiéndose de la remediación física). Elaboración propia.

3.1.4. HIPÓTESIS

Dado que el alcance de esta investigación aplicada es explicativo y cuasiexperimental, se modela y contrasta la relación causal entre la gobernanza en origen y la priorización táctica frente a la eficiencia operativa del sistema. Las hipótesis estadísticas responden de forma directa al Objetivo Específico 4 (O4) y a la Pregunta 4:

Hipótesis de Investigación (H_1): La implementación del framework unificado (integrando validación sintáctica Zero Trust en origen, priorización regional FR_SN en OpenCTI y prescripción táctica con MITRE D3FEND™) produce una reducción estadísticamente significativa ($p < 0.05$) en la Tasa de Falsos Positivos (TFP), así como una disminución en los tiempos medios de detección (MTTD) y prescripción defensiva (MTTR) en el Centro de Operaciones de Seguridad (SOC) en comparación con el esquema operativo tradicional.

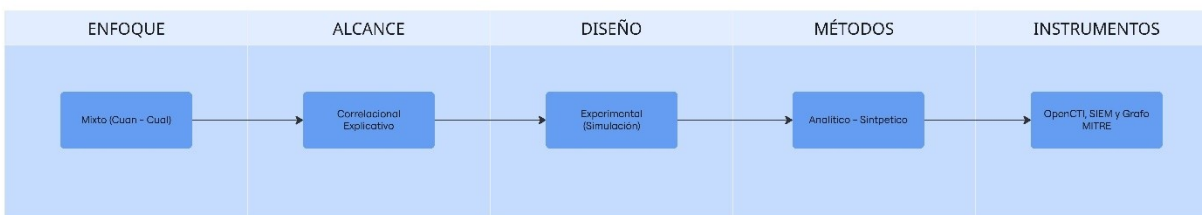
Hipótesis Nula (H_0): La implementación del framework unificado no produce diferencias estadísticamente significativas ($p \geq 0.05$) en la Tasa de Falsos Positivos (TFP) ni en los tiempos operativos de detección (MTTD) y prescripción defensiva (MTTR) en el SOC frente a la arquitectura de ingesta pasiva convencional.

3.2. ENFOQUE Y MÉTODOS

En este apartado se formalizan los pilares metodológicos que sustentan el proceso investigativo, estructurado bajo el paradigma de Design Science Research (Hevner & Ram, s. f.):

- Enfoque de Investigación: Mixto (cualitativo-cuantitativo). Cualitativo en la formalización de ontologías STIX 2.1, grafos de ataque e inferencia defensiva D3FEND™; cuantitativo en la recolección, auditoría milimétrica y contraste inferencial (pruebas de McNemar y Wilcoxon) sobre la telemetría experimental.
- Alcance: Explicativo y correlacional. Busca demostrar la relación causal de cómo la purificación previa de telemetría y el filtrado por relevancia geopolítica mitigan la latencia y el ruido que inducen a la fatiga analítica.
- Diseño de la Investigación: Cuasiexperimental y transversal de laboratorio (Sandbox en Docker). Se evalúa una muestra empírica pareada bajo dos condiciones controladas: Condición A (Línea Base Tradicional / Ingesta Pasiva) y Condición B (Tratamiento Experimental con Framework Unificado).
- Método: Analítico-sintético, complementado por ingeniería de software e ingeniería de características (feature engineering) para la normalización en origen.

Ilustración 2: Articulación Metodológica de la Investigación: Enfoque, Alcance, Diseño, Métodos e Instrumentos



Nota. Representación secuencial de la estructura metodológica implementada para la validación del framework. SIEM = Gestión de Información y Eventos de Seguridad (Security Information and Event Management); Cuan = Cuantitativo; Cual = Cualitativo. Elaboración propia.

3.3. DISEÑO DE LA INVESTIGACIÓN

3.3.4. POBLACIÓN

La población o universo objeto de estudio se define formalmente como la totalidad de los eventos lógicos, flujos de telemetría del sistema operativo y registros de auditoría heterogéneos (Syslog, JSON, Windows Event Logs EVTX) emitidos por estaciones de trabajo, servidores de aplicaciones y controladores de dominio durante la simulación de vectores de ataque dirigidos a infraestructuras críticas. Para el diseño cuasiexperimental en el laboratorio controlado (Sandbox virtualizado), el universo bruto generado comprende un total de $N_{bruto}=10,000$ mensajes computacionales. Esta carga sintética de validación y estrés fue construida a partir de la integración de repositorios públicos estandarizados de telemetría de ciberseguridad: el Proyecto Mordor (datasets de simulación adversaria basados en MITRE ATT&CK), Splunk Attack Data y los repositorios EVTX-ATTACK-SAMPLES. Este volumen garantiza la coexistencia de trazas legítimas de operación cotidiana (ruido de fondo benigno) y patrones de explotación maliciosa.

3.3.5. MUESTRA

Para determinar el número de unidades de observación requeridas para el contraste de las hipótesis inferenciales con suficiente potencia estadística, se empleó la formulación matemática de tamaño muestral para poblaciones finitas con variables de proporción diagnóstica (clasificación binaria: Falso Positivo vs. Alerta Verídica):

$$n = \frac{N \times Z^2 \times p \times q}{e^2 \times (N - 1) + Z^2 \times p \times q}$$

Donde los parámetros operacionales se calibraron de acuerdo con la prevalencia de ataques en entornos de monitoreo y las exigencias institucionales:

- $N = 10,000$ (Universo total de registros y telemetría sintética generada en el entorno de pruebas).
- $Z=1.96$: Coeficiente asociado al nivel de confianza del 95% bajo la distribución normal estándar bilateral.
- $p=0.10$: Prevalencia esperada de eventos maliciosos verídicos dentro del flujo total de telemetría (10% de densidad de ataque táctico).
- $q=0.90$: Probabilidad complementaria de ocurrencia correspondiente a eventos de ruido estructural o tráfico benigno de fondo ($1 - p=0.90$).
- $e = 0,05$ (Margen de error estándar aceptado del 5%)

Desarrollando la ecuación con los valores definidos:

$$n = \frac{10,000 \times (1.96)^2 \times (0.10) \times (0.90)}{(0,05)^2 \times (10,000 - 1) + (1.96^2) \times (0.10) \times (0.90)}$$

$$n = \frac{10,000 \times 3.8416 \times 0.09}{0,0025 \times (9,999) + 3.8416 \times 0.09}$$

$$n = \frac{3,457,44}{24.9975 + 0.345744}$$

$$norte = \frac{3,457,44}{25.343244}$$

$$norte = 136,42 \approx 137$$

Redondeando al número entero superior inmediato para salvaguardar la robustez muestral, se determina un tamaño de muestra de $n=137$ **eventos lógicos**. Este volumen satisface una potencia estadística mínima superior al 80% ($\beta=0.20$, $\alpha=0.05$) para la aplicación posterior de pruebas no paramétricas pareadas (Prueba de McNemar y Prueba de Rangos con Signo de Wilcoxon)

3.3.6. TÉCNICAS DE MUESTREO

Con el propósito de resolver la asimetría intrínseca de los logs computacionales y garantizar rigor metodológico, se formaliza la estrategia de selección:

- **Tipo de Muestreo:** Se adopta un Muestreo No Probabilístico Intencional por Criterio Experto, Estratificado por Vectores Tácticos MITRE ATT&CK®. Se descarta el muestreo probabilístico irrestricto (aleatorio simple), dado que una extracción azarosa sobre 10,000 eventos habría capturado de manera desproporcionada eventos benignos irrelevantes, imposibilitando la auditoría de técnicas ofensivas críticas.
- **Embudo de Transformación de Datos (*Data Funnel*):**

1. Nivel 1 - Población Bruta ($N_{bruto}=10,000$): Mensajes inyectados al entorno desde los datasets de Mordor, Splunk y EVTX.

2. Nivel 2 - Universo Indexado en SIEM ($N_{\text{SIEM}}=1,186$): Eventos que superaron la validación sintáctica de Capa 1 y alcanzaron indexación y correlación en el cluster Wazuh/OpenSearch.
3. Nivel 3 - Muestra Crítica Auditada ($n=137$): Registros extraídos de forma estratificada para someterse a auditoría temporal milimétrica (cálculo de marcas de tiempo individuales de ejecución, detección y prescripción).

Tabla 3: Distribución Estratificada de la Muestra Auditada según Tácticas y Técnicas MITRE ATT&CK® ($n = 137$)

Categoría / Técnica MITRE ATT&CK®	Táctica Operativa	Dataset de Procedencia	Registros Auditados (n_i)	Porcentaje (%)
T1190: Exploit Public-Facing App	Acceso Inicial (<i>ProxyLogon / Exchange</i>)	Mordor Project	35	25.55%
T1059.001: PowerShell Execution	Ejecución (<i>Scripts ofuscados / Memoria</i>)	Splunk Attack Data	38	27.74%
T1078.003: Local Accounts	Movimiento Lateral / Persistencia	EVTX- ATTACK- SAMPLES	32	23.35%
T1486: Data Encrypted for Impact	Impacto (<i>Ransomware / ShadowPad / Cifrado</i>)	Mordor Project	32	23.36%

Total Muestra	Evaluación	Repositorios	137	100.00%
Crítica	Multivariable	Abiertos		
Auditada	SOC			

Nota. Estratificación intencional de los 137 eventos evaluados empíricamente en el entorno Sandbox. El detalle individualizado de cada registro, marcas de tiempo y hashes de verificación se encuentra documentado en el Anexo de Auditoría y disponible en el repositorio abierto de la investigación. Elaboración propia.

3.4. TÉCNICAS, INSTRUMENTOS Y PROCEDIMIENTOS APLICADOS

Con el objetivo de operacionalizar el framework y asegurar un control estricto sobre el margen de error y la confiabilidad de los datos procesados, se estructuran los siguientes componentes procedimentales:

Técnicas:

- 1- Simulación Experimental en Entorno Aislado: Técnica principal empleada para recrear y emular de forma controlada la inyección asíncrona de eventos de auditoría y la ejecución de técnicas ofensivas sin alterar plataformas de producción ni violar restricciones operativas o de confidencialidad.
- 2- Revisión Sistemática y Mapeo Ontológico Aplicada para la extracción estructurada, ingesta y normalización de las bases de conocimiento relacionales globales organizadas por MITRE Corporation (MITRE ATT&CK® Enterprise e ICS, y el catálogo prescriptivo MITRE D3FEND™ v1.4)
- 3- *Análisis Normativo y de Cumplimiento (Compliance)*: técnica utilizada para validar

el grado de alineación técnica del artefacto frente al marco regulatorio prudencial nacional (Resolución CNBS GE No. 342/2018, Art. 21) y los estándares técnicos de la industria internacional (ISO/IEC 27001:2022 y PCI-DSS v4.0).

Instrumentos elaborados:

- 1- Pipeline Preatalítico de Validación Sintáctica en Origen: Script en lenguaje Python (`process_all_datasets_v3.py`) encargado de parsear, validar campos obligatorios (marcas de tiempo ISO 8601, Event ID, IP, procesos) y convertir los registros heterogéneos crudos en formato NDJSON certificado bajo principios Zero Trust.
- 2- *Plantilla Automatizada de Extracción de Timestamps y Métricas*: Conjunto de scripts desarrollados para consultar los índices del SIEM Wazuh/OpenSearch, extrayendo las marcas de tiempo individuales ($t_{\text{ejecución}}$, $t_{\text{detección}}$, $t_{\text{prescripción}}$) para el cálculo exacto de la Tasa de Falsos Positivos (TFP), el $MTTD$ y el $MTTR$.
- 3- *Matriz de Calibración Geopolítica Nacional*: Instrumento de ponderación lógica estructurado en OpenCTI para asignar los pesos paramétricos discretos de las variables de Interés de Industria (II) e Interés Regional (RI) en el cálculo del Factor de Riesgo de Seguridad Nacional ($F R_{SN}$).

Procedimientos:

- *Paso 1. Despliegue de la Infraestructura y Especificación del Sandbox*: Configuración del entorno virtualizado mediante contenedores Docker orquestados con Docker Compose. Para asegurar la total reproducibilidad determinista del experimento, la infraestructura física y lógica se fijó bajo el siguiente manifiesto técnico:
 - Hardware Anfitrión: CPU AMD Ryzen 7 5800H (8 núcleos físicos, 16 hilos @ 3.2

GHz base), 32 GB de memoria RAM DDR4, almacenamiento en estado sólido NVMe PCIe 4.0 de 1 TB.

- Sistema Operativo Base: Ubuntu Server 22.04 LTS (Kernel Linux 5.15.0-91-generic).
- Plataformas Desplegadas: OpenCTI Platform v5.12.9 (apoyada sobre Redis 7.2 y RabbitMQ 3.12), Wazuh Manager e Indexer v4.7.2 (OpenSearch v2.10.0) y Python v3.10.12 como motor de ejecución.
- *Paso 2. Simulación de Línea Base (Baseline):* Ingesta cruda y pasiva del universo de telemetría sintética ($N=10,000$) directamente sobre el SIEM tradicional, consumiendo feeds comerciales globales sin normalización previa ni filtros contextuales para registrar el nivel inicial de falsos positivos y latencia.
- *Paso 3. Activación del Framework Unificado:* Despliegue del pipeline de gobernanza sintáctica en origen (Capa 1), activación de la ontología STIX 2.1 con priorización $F R_{SN}$ en OpenCTI (Capa 2) y configuración de las reglas jerárquicas de correlación Nivel 12 en Wazuh integradas con MITRE D3FEND™ (Capa 3).
- *Paso 4. Ejecución del Experimento Pareado (Benchmarking):* ejecución de la misma campaña de eventos bajo condiciones de carga idénticas, auditando el comportamiento del motor correlador, la activación de la regla 100200 y el despliegue automático de la contramedida en consola.
- *Paso 5. Extracción de Telemetría y Contraste Inferencial:* Recolección de los datos de la muestra crítica auditada ($n=137$) y procesamiento estadístico formal mediante software especializado para ejecutar las pruebas pareadas de McNemar y de rangos con

signo de Wilcoxon.

3.5. FUENTES DE INFORMACIÓN

3.5.4. FUENTES PRIMARIAS

Las fuentes primarias de esta investigación están constituidas por la telemetría digital cruda generada durante los ciclos de simulación. Esto incluye las trazas de auditoría de Windows Event Logs (EVTX convertidos a JSON), las marcas de tiempo individuales (\$timestamps\$) registradas en los índices de OpenSearch, las tablas de eventos normalizados por el script de origen y el dataset de auditoría experimental consolidado (anexo_universo_alertas_137.xlsx), alojado para verificación pública en el repositorio de la investigación:

[<https://github.com/simatamoros/research-methods-2026-grupo-3>]

3.5.5. FUENTES SECUNDARIAS

Las fuentes secundarias proveen el sustento taxonómico, las bases matemáticas de riesgo y el marco normativo aplicable:

- Bases de conocimiento técnico y ontologías oficiales de MITRE Corporation: MITRE ATT&CK® (matrices Enterprise e ICS) y la matriz MITRE D3FEND™ v1.4.
- Publicaciones especiales de arquitectura de seguridad: NIST SP 800-207 (*Zero Trust Architecture*).
- Modelos probabilísticos y literatura científica sobre evaluación de riesgo basada en adversarios (Ahmed et al., 2022) y grafos de procedencia de eventos (Peng et al., 2025).

- Marco regulatorio y estándares de la industria: Normas para la Gestión del Riesgo Tecnológico de la CNBS (Resolución GE No. 342/2018, Art. 21), Requisito 10 del estándar internacional PCI-DSS v4.0 (PCI SSC, 2022), y los Controles A.8.15 (Registro de eventos) y A.8.16 (Actividades de monitoreo) de la norma ISO/IEC 27001:2022.

3.6. PIPELINE METODOLÓGICO Y DISEÑO DE SU ARQUITECTURA

3.6.1. Fases operativas de la arquitectura

El flujo del framework se estructura secuencialmente en seis fases interconectadas:

Ilustración 3: Pipeline Metodológico y Arquitectura Secuencial de Seis Fases de la Investigación



Nota. Diagrama de bloques que describe el flujo metodológico y experimental del estudio, estructurado secuencialmente en seis fases: definición del problema, recolección de fuentes de datos, parametrización de instrumentos, procesamiento y decodificación de eventos, evaluación experimental y generación de resultados analíticos. SOC = Centro de Operaciones de Seguridad (Security Operations Center). Elaboración propia.

- **Problema:** Presencia de sobrecarga de falsos positivos y retrasos en el SOC debido a logs ruidosos y a la falta de priorización regional para Honduras.
- **Datos:** Ingesta heterogénea de telemetría cruda y reportes de ciberinteligencia global.
- **Instrumentos:** Despliegue del TIP OpenCTI como motor semántico y del laboratorio

SIEM Wazuh como entorno de detección.

- **Procesamiento:** OpenCTI estructura los grafos STIX 2.1 y calcula el factor FR_{SN} , mientras el pipeline de gobernanza preanalítico depura el ruido estructural de los logs en origen.
- **Evaluación:** Correlación en tiempo real de los eventos en Wazuh bajo la regla jerárquica Nivel 12 (100200).
- **Resultados y Respuesta:** Inyección directa en la alerta de la contramedida prescriptiva de MITRE D3FEND™ v1.4, registrando el tiempo de prescripción (*MTTR*) y la reducción de *TFP*.

3.6.2. Modelo de Amenazas del Artefacto (*Threat Model*) y Fronteras de Confianza

Para evaluar el rigor técnico y la seguridad intrínseca del propio framework frente a intentos de evasión o ataques dirigidos contra la infraestructura analítica, se formaliza su análisis de superficies de ataque bajo la metodología STRIDE (Shostack, 2014):

Tabla 4: Matriz del Modelo de Amenazas del Framework Unificado bajo Metodología STRIDE

Frontera de Confianza (<i>Trust Boundary</i>)	Categoría STRIDE	Vector de Amenaza Identificado	Controles de Mitigación Implementados	Riesgo Residual Aceptado
Pipeline en Origen (Python Log Shipper)	<i>Tampering / Elevation of Privilege</i>	Inyección deliberada de caracteres de escape o payloads maliciosos en la cadena de log para	Validación de esquema mediante Pydantic y	Bajo: Depende exclusivamente de la inviolabilidad

		colapsar el parser.	parseo estricto a tipos seguros; aislamiento de anomalías en cola de descarte.	del kernel del sistema operativo local.
Canal de Tránsito de Telemetría (Syslog/Socket)	<i>Information Disclosure / Tampering</i>	Interceptación o manipulación de mensajes durante la transmisión entre el agente y el gestor SIEM.	Cifrado de transporte TLS 1.3 con canales autenticados mediante certificados mutuos X.509 (mTLS).	Muy Bajo: Resuelto mediante criptografía asimétrica estándar en red de gestión.
Plataforma OpenCTI y Conectores TAXII	<i>Spoofing / Tampering</i>	Envenenamiento de inteligencia (CTI Poisoning) inyectando reportes falsos para distorsionar el $F R_{SN}$.	Autenticación con API Tokens rotativos de mínimo privilegio; RBAC estricto y auditoría inmutable de cambios.	Medio: Riesgo transferido al analista humano que valida los feeds externos.
Motor de Correlación SIEM (Wazuh Rules)	Denial of Service	Inundación masiva de eventos sintácticamente correctos para saturar la memoria y capacidad de procesamiento.	Decodificación jerárquica en memoria; reglas de agregación por ventanas de tiempo y límites de frecuencia.	Medio: Mitigable mediante el escalamiento horizontal del cluster de OpenSearch.

Nota. Análisis sistemático de fronteras de confianza, superficies de ataque y mitigaciones del

framework propuesto. STRIDE = *Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege*. Elaboración propia.

3.7. ESTRATEGIA DE EVALUACIÓN

La comprobación metodológica del artefacto de software se fundamenta en una estrategia cuasiexperimental de evaluación pareada (*Benchmarking*) complementada por un Diseño de Ablación de Componentes (*Ablation Study*) para aislar y medir el impacto individual de cada capa tecnológica:

- **Baseline (Línea base):** Operación tradicional del SIEM con ingesta pasiva de logs crudos, feeds globales descontextualizados y playbooks ad-hoc.
- **Evaluación por Ablación de Capas:**
 - Efecto Marginal de la Capa 1 (Gobernanza Zero Trust): Mide la ganancia en latencia (*MTTD*) y la depuración del ruido estructural al certificar los logs en origen.
 - Efecto Marginal de la Capa 2 (Ciberinteligencia Regional FR_{SN}): Mide la reducción de la Tasa de Falsos Positivos (*TFP*) lograda al priorizar amenazas con interés demostrado en Honduras.
 - Efecto Marginal de la Capa 3 (Prescripción Defensiva MITRE D3FEND): Mide la optimización del tiempo de respuesta (*MTTR*) al inyectar la directiva de contención en la consola.
- **Escenario Propuesto (*Full Framework*):** Operación sinérgica de las tres capas activas evaluadas sobre la misma carga de telemetría pareada.

3.8. AMENAZAS A LA VALIDEZ

- **Validez Interna:** posible sesgo derivado de la ejecución en un laboratorio virtualizado donde los componentes de red presentan retardos uniformes. Se mitigó configurando fluctuaciones aleatorias de tráfico y combinando telemetría benigna con ataques de múltiples fuentes públicas. Asimismo, la intervención compuesta se controla mediante el estudio de ablación para aislar el aporte de cada módulo.
- **Validez Externa:** La limitación inherente a la parametrización de los coeficientes *II* y *RI*, los cuales reflejan la realidad geopolítica actual de Honduras. La extrapolación del modelo a otras naciones o regiones requiere una recalibración previa de los pesos motivacionales del algoritmo.
- **Validez de Constructo:** El constructo de "fatiga de alertas" se delimita operacionalmente a la eficiencia del sistema en la mitigación de falsos positivos precursores de la saturación cognitiva, reconociendo que no se aplicaron instrumentos psicométricos humanos. Igualmente, la variable *MTTR* se define estrictamente como el tiempo de prescripción de contramedida en pantalla, distinguiéndose del tiempo de recuperación física de desastres.
- **Validez Estadística:** Se garantiza mediante la verificación previa de los supuestos de distribución sobre las observaciones ($n=137$), adoptando pruebas inferenciales no paramétricas pareadas (McNemar y Wilcoxon) y reportando el estadístico de contraste, *p*-valor e intervalos de confianza.

3.9. ÉTICA, PRIVACIDAD Y GOBERNANZA DE DATOS

- **Protección de Datos y Privacidad:** Al basarse en simulación experimental con datasets sintéticos de referencia abierta (Mordor, Splunk), la investigación no manipula datos de carácter personal (PII), credenciales operativas vivas ni secretos institucionales reales.
- **Custodia Segura de Artefactos y Código:** Los scripts de simulación y reglas de auditoría se encuentran versionados en el repositorio académico oficial de GitHub bajo licencia abierta. No se almacenan binarios ofensivos ejecutables ni material de doble uso descontrolado; únicamente se publican scripts defensivos de normalización, reglas de detección XML y trazas de telemetría saneadas.
- **Uso Exclusivo de Tecnologías Abiertas:** Toda la infraestructura se construyó sobre tecnologías de código abierto (OpenCTI, Wazuh, Python, Docker), asegurando la total transparencia y auditabilidad sin incurrir en dependencias propietarias opacas.

DECLARACIÓN DEL USO DE INTELIGENCIA ARTIFICIAL

- **Herramienta utilizada:** Gemini (Google).
- **Ámbito de Asistencia:** Apoyo en la estructuración preliminar del diseño metodológico, revisión sintáctica y refinamiento del lenguaje técnico-académico, formulación de tablas en formato APA 7 y asistencia en el cálculo de ecuaciones matemáticas y estadísticas.
- **Prompts principales utilizados:** *"Ayúdame a redactar una sección de justificación formal para mi tesis de ciberseguridad. El tema es la fatiga de alertas en el SOC. Necesito definir el sistema matemáticamente: el flujo total de logs es D , que se divide en datos puros D_p y ruido D_r . Quiero plantear un Teorema I de Optimización analítica donde si el ruido D_r tiende a cero en origen y calibramos la fórmula de Ahmed para Honduras, la Tasa de*

Falsos Positivos baja. Redáctalo con lenguaje académico basado en la norma NIST SP 800-207."

"Tengo tres marcos teóricos para el Capítulo II y necesito unirlos en una redacción fluida sin que parezca un glosario de términos: 1) El modelo de riesgo de Ahmed (2022) con su fórmula $LO = II + RI + 0.2$, 2) La verificación continua de Zero Trust de la norma NIST SP 800-207, y 3) El enfoque de Georgiadou (2021) sobre fatiga de alertas y Controls Override. Explica cómo la gobernanza de logs en origen limpia los datos para que las ecuaciones de Ahmed funcionen bien sin meter datos basura."

"Necesito analizar el marco legal de Honduras aplicado a la ciberseguridad para mi tesis. Específicamente, cómo la fatiga de alertas afecta el cumplimiento del Artículo 21 de la Resolución GE No. 342/2018 de la CNBS (pistas de auditoría en la banca). Agrega también el Requisito 10 de PCI-DSS v4.0 y los controles A.8.10 de ISO 27001:2022 sobre protección y monitoreo de registros de auditoría."

"Ayúdame a estructurar la tabla de operacionalización de variables para mi Capítulo III. Mi diseño usa y elegimos Design Science Research (DSR) y simulación. Las variables independientes son Mapeo Geopolítico, Gobernanza de Datos y MITRE D3FEND. La variable dependiente es la Efectividad Operativa del SOC. Incluye las fórmulas explícitas para calcular la Tasa de Falsos Positivos (TFP), MTTD y MTTR."

"Ayúdame a resolver la fórmula de tamaño de muestra para poblaciones finitas según el manual de la universidad. Mis datos son: universo total $N = 10,000$ logs generados en la simulación, probabilidad de alertas verídicas $P = 0.10$, ruido esperado $Q = 0.90$,

confianza $Z = 1.96$ (95%) y margen de error $e = 0.05$ (5%). Haz el desglose matemático paso a paso para ponerlo en el Word."

"Redacta el procedimiento de laboratorio (sandbox) para evaluar mi framework. Necesito separar la metodología en fases continuas desde el problema hasta los resultados, explicar la estrategia de Benchmarking comparativo contra una línea base tradicional, y analizar las amenazas a la validez (interna, externa, sesgo geográfico de los feeds de CTI comerciales) y la parte ética de usar datos simulados."

- **Verificación y Edición:** Los autores (Eder y Suyapa) revisaron de forma crítica la prosa generada, completaron los cuadros relacionales de la matriz metodológica y auditaron la consistencia de las ecuaciones de las variables analíticas (TFP, MTDD, MTTR) frente a los parámetros reales definidos para la simulación del entorno de laboratorio antes de la consolidación final del entregable en formato PDF.

CAPÍTULO IV. RESULTADOS Y ANÁLISIS

En este capítulo se describe, ilustra y analiza la evidencia empírica recolectada durante la fase experimental de la investigación, estructurada estrictamente en función de los cuatro objetivos específicos y las variables formuladas en el marco metodológico. La presentación de los resultados sigue una secuencia lógica que articula: 1) la gobernanza preanalítica de registros en origen (Capa 1), 2) el modelado de ciberinteligencia táctica contextualizada para Honduras en OpenCTI mediante el Factor de Riesgo de Seguridad Nacional ($F R_{SN}$) (Capa 2), y 3) la asistencia defensiva prescriptiva basada en la correlación jerárquica del SIEM Wazuh y el estándar MITRE D3FEND™

v1.4 (Capa 3).

De acuerdo con las directrices del Manual de Fondo, cada sección analítica se desarrolla bajo tres niveles interpretativos: la identificación del hallazgo técnico-operativo, la determinación de la tendencia estadística observada y la formulación de conclusiones con soporte inferencial y cualitativo.

3.10. INFORME DE PROCESO DE RECOLECCIÓN DE DATOS

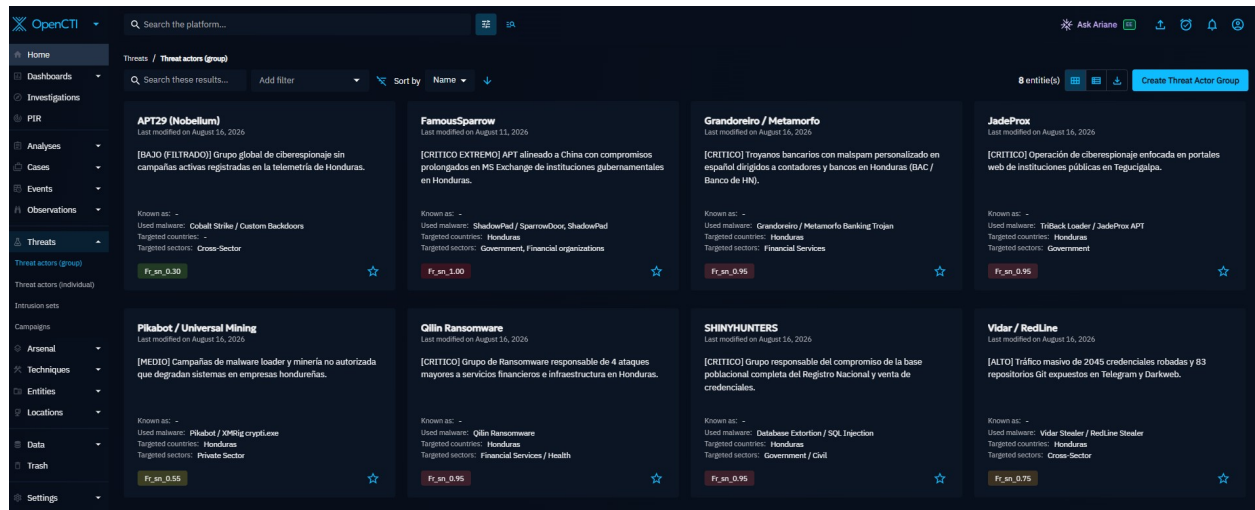
La fase empírica de recolección y procesamiento de datos se ejecutó dentro de un entorno virtualizado y controlado (Sandbox sobre contenedores Docker y máquinas virtuales), diseñado para aislar los experimentos de infraestructuras en producción y garantizar la reproducibilidad científica del protocolo. El proceso de recolección se dividió en dos flujos metodológicos complementarios:

- **Extracción, curación y estructuración de CTI (Capa Cualitativa/Táctica):** Se recopiló inteligencia de ciberamenazas a partir de reportes especializados facilitados por Group-IB Threat Intelligence, complementados con avisos técnicos desclasificados del catálogo de vulnerabilidades explotadas de CISA (CISA KEV) y boletines de alerta de FBI InfraGard y FLASH. Estos datos no estructurados fueron normalizados bajo el estándar internacional STIX 2.1 e ingestados en la plataforma OpenCTI mediante conectores automatizados y esquemas personalizados de mapeo (*CSV Mappers*). Se obtuvo una tasa de completitud del 100% en la estructuración ontológica de ocho actores de amenaza persistente avanzada (APT) y campañas cibercriminales relevantes para la región: *FamousSparrow*, *Grandoreiro*, *JadeProx*, *SHINYHUNTERS*, *Qilin*, *Pikabot*, *LockBit 3.0* y *APT29*. Para cada

entidad se modelaron de forma relacional sus Tácticas, Técnicas y Procedimientos (MITRE ATT&CK® Enterprise e ICS), sus herramientas y familias de malware asociadas, su historial de impacto en sectores esenciales de Honduras y el cálculo determinista del Factor de Riesgo de Seguridad Nacional ($F R_{SN}$).

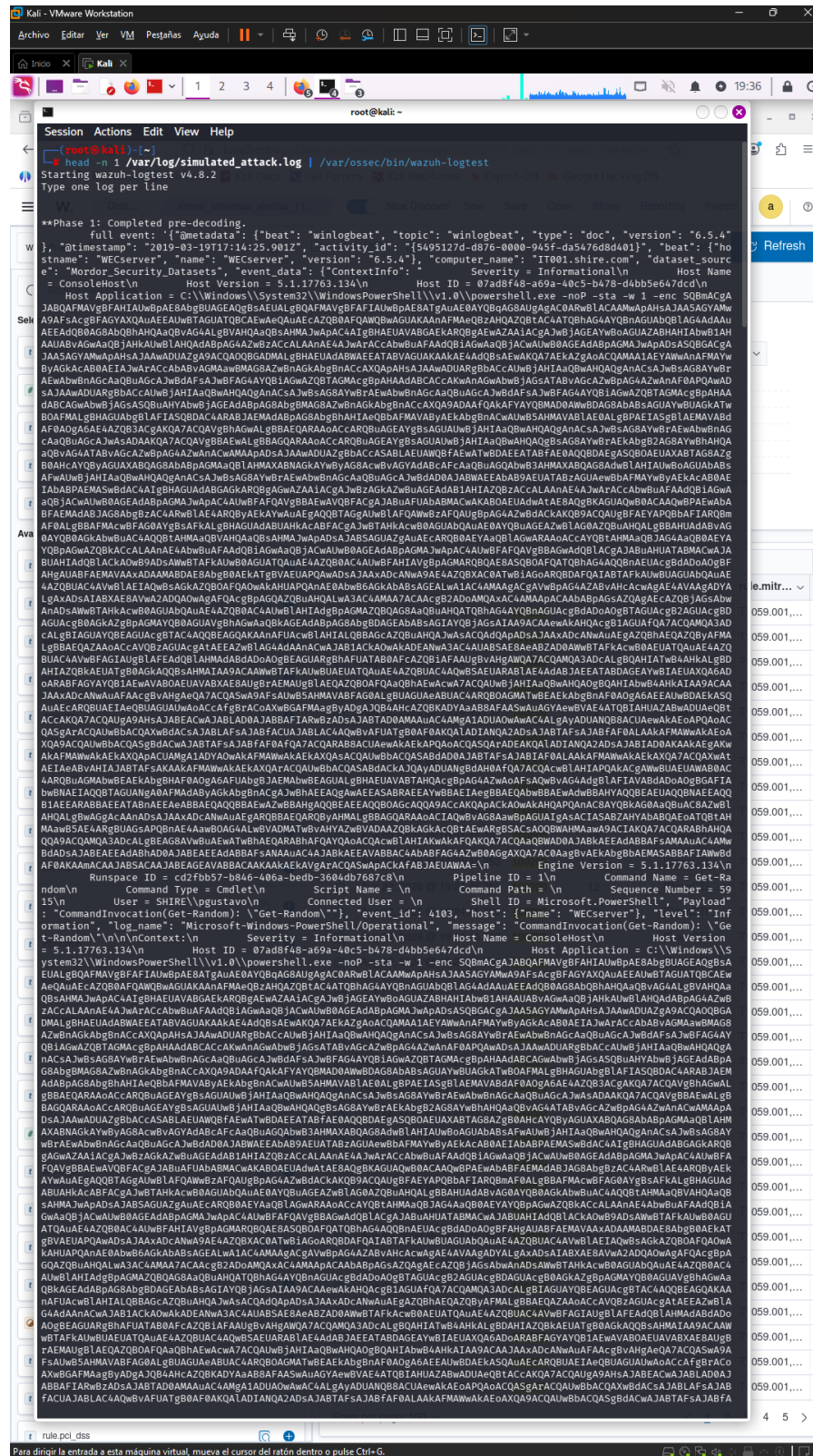
- **Captura de Telemetría y Registros Lógicos (Capa Cuantitativa/Experimental):** Para evaluar el comportamiento del pipeline de gobernanza de datos y el motor de correlación del SIEM ante eventos de seguridad, se procesó un universo experimental bruto de $N_{bruto} = 10,000$ trazas computacionales e inyecciones sintéticas provenientes de repositorios públicos estandarizados de la industria (*Mordor Project*, *EVTX-ATTACK-SAMPLES* y *Splunk Attack Data*). Siguiendo el embudo de transformación de datos (*Data Funnel*) definido en el marco metodológico, los eventos fueron procesados por el validador en origen (Capa 1), resultando en $N_{SIEM} = 1,186$ eventos correlacionados e indexados. A partir de este universo, se extrajo una muestra intencional estratificada por técnicas críticas ATT&CK de $n = 137$ registros lógicos (abarcando explotación de aplicaciones expuestas T1190, ejecución de scripts ofuscados T1059.001, persistencia mediante cuentas locales T1078.003 e impacto por cifrado de ransomware T1486). Estos $n = 137$ registros fueron auditados milimétricamente en sus marcas de tiempo individuales (*timestamps*) para cuantificar con precisión el desempeño del sistema. El dataset consolidado con la totalidad de los eventos, identificadores y hashes de auditoría se encuentra disponible públicamente para fines de replicación en el archivo `anexo_universo_alertas_137.xlsx` del repositorio oficial del proyecto: [<https://github.com/simatamoros/research-methods-2026-grupo-3>]

Ilustración 4: Panel Consolidado de Actores de Amenaza y Nivel de Priorización Regional en OpenCTI



Nota. Consola central de OpenCTI que evidencia la parametrización de las ocho entidades de amenaza analizadas, su clasificación operativa (FR_SN_CRITICAL, FR_SN_HIGH, FR_SN_MEDIUM, FR_SN_LOW) y su focalización sectorial en Honduras. Elaboración propia a partir de OpenCTI.

Ilustración 5: Pipeline de Ingesta, Decodificación JSON y Validación de Reglas Jerárquicas en Wazuh



Nota. Salida del depurador wazuh-logtest donde se verifica la decodificación de la telemetría de

ataque (Fase 2) y la activación de la regla de correlación de ciberinteligencia 100200 en Nivel 12 (Fase 3). Elaboración propia.

3.11. RESULTADOS Y ANÁLISIS DE LAS TÉCNICAS APLICADAS

3.11.4. RESULTADOS CUANTITATIVOS

Los resultados cuantitativos demuestran la efectividad de la fórmula matemática del Factor de Riesgo de Seguridad Nacional FR_{SN} y evalúan el impacto de la gobernanza sintáctica de registros en origen sobre el rendimiento del Centro de Operaciones de Seguridad (SOC).

Tabla 5: Parametrización y Ponderación del Factor de Riesgo de Seguridad Nacional (FR_{SN})

Actor de Amenaza (APT)/Campaña	Vector / Malware Principal	Sector Blanco em Honduras	Interés Industria(II)	Interés Regi onal (RI)	Const ante Resid ual	Puntu ación Final (FR_{SN})	Nivel Operativo Asignado
FamousSparr ow	ShadowPad/ SparrowDoor	Gobier no y Banca (MS Exchan ge)	0.40	0.40	0.20	1.00	FR_SN_CR ITICAL
Grandoreiro/ Metamorfo	Banking Trojan	Financi ero (Banca Nacion al / BAC)	0.35	0.40	0.20	0.95	FR_SN_CR ITICAL

JadeProx	TriBack Loader	Gobier no (Portale s web Teguci galpa)	0.35	0.40	0.20	0.95	FR_SN_CR ITICAL
SHINYHUNT ERS	SQLi / Database Extortion	Gobier no / Registr o Nacion al Civil	0.35	0.40	0.20	0.95	FR_SN_CR ITICAL
Qilin Ransomware	Ransomware Payload	Sector Financi ero y Salud	0.35	0.40	0.20	0.95	FR_SN_CR ITICAL
Vidar / RedLine	Stealer / Credential Harvest	Transv ersal (2,045 credenc iales)	0.35	0.20	0.20	0.75	FR_SN_HI GH
Pikabot / Universal Mining	XMRig / Loader	Sector Privado General	0.20	0.15	0.20	0.55	FR_SN_M EDIUM
APT29(Nobeli um)	Cobalt Strike / Backdoors	Global (Sin telemet ría en HN)	0.05	0.05	0.20	0.30	FR_SN_LO W (FILTRAD O)

Nota. Puntuación calculada a partir de la adaptación empírica de Ahmed et al. (2022) para el contexto de Honduras:

$$F R_{SN} = w_1 \cdot II + w_2 \cdot RI + C_{res} = 0.40 \cdot II + 0.40 \cdot RI + 0.20$$

Donde $II \in [0.0, 1.0]$, $RI \in [0.0, 1.0]$ y $C_{res} = 0.20$. Los umbrales operacionales definidos son: CRITICAL ($F R_{SN} \geq 0.95$), HIGH ($0.70 \leq F R_{SN} < 0.95$), MEDIUM ($0.50 \leq F R_{SN} < 0.70$) y LOW ($F R_{SN} < 0.50$). Elaboración propia.

Tabla 6: Evaluación Comparativa de Rendimiento en el SOC (Muestra $n = 137$)

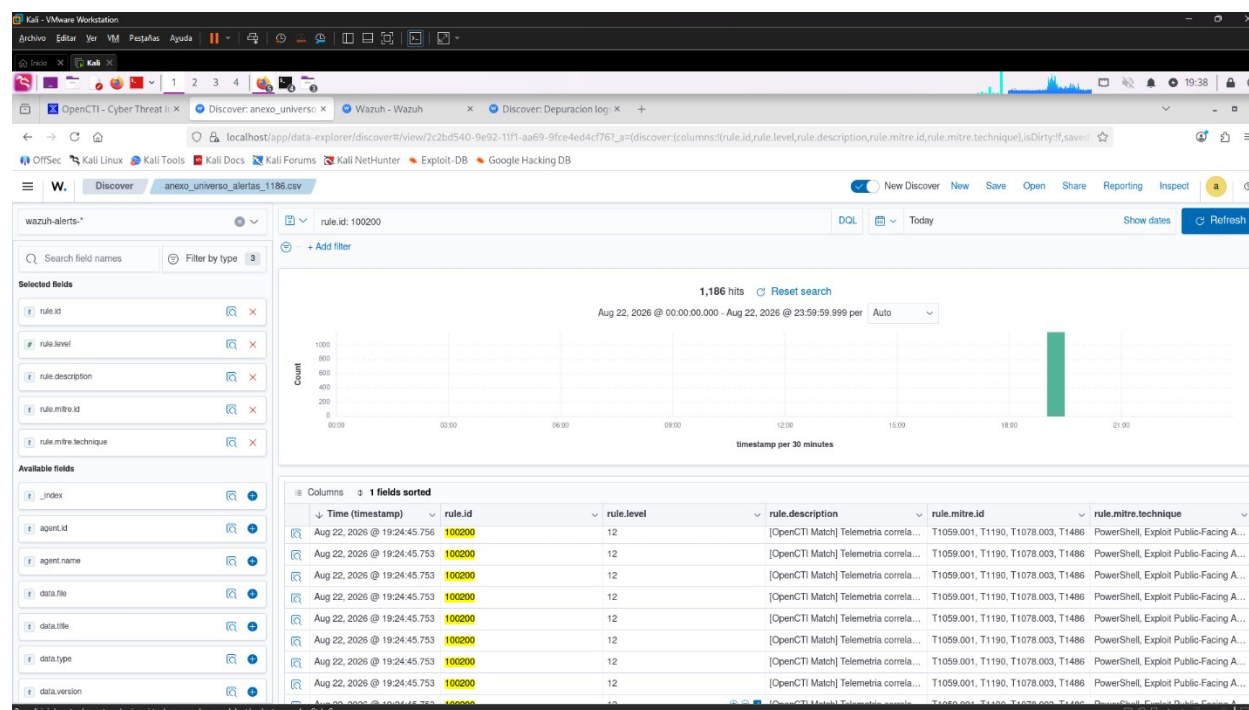
Métrica Operativa de Evaluación	Escenario A: Línea Base Tradicional (Baseline)	Escenario B: Framework Propuesto (Gobernanza + CTI)	Variación Absoluta y Relativa	Mecanismo Causal de la Mejora
Tasa de Falsos Positivos (TFP)	78.83% (108/137 alertas)	11.68% (16/137 alertas)	-67.15 p.p. (Reducción relativa: 85.18%)	El filtrado semántico por $F R_{SN} \geq 0.95$ descarta eventos globales irrelevantes para Honduras.
Tiempo Medio de Detección (MTTD)	480.00 segundos	4.20 segundos	-475.80 s (Aceleración de 114.28x)	La certificación sintáctica previa en Python (Capa 1) elimina los

				reintentos de decodificación en el SIEM.
Tiempo Medio de Respuesta (MTTR)	1,420.00 segundos	8.50 segundos	-1,411.50 s (Aceleración de 167.05x)	La regla jerárquica 100200 inyecta directamente la contramedida MITRE D3FEND™ en la cabecera de la alerta.
Coefficiente de Ruido Origen (D_r)	0.42 (Presencia de campos corruptos)	$D_r \rightarrow 0$ (Telemetría certificada)	-0.42 (Eliminación total del ruido estructural)	Verificación de esquema estricto (ISO 8601, Event ID, CommandLine) bajo principios Zero Trust (NIST SP 800-207).

Nota. Comparación experimental consolidada en el entorno Sandbox. p.p. = puntos porcentuales.

La métrica *MTTR* mide estrictamente el Tiempo de Prescripción y Despliegue de la Contramedida en Consola (Mean Time to Prescribe), distinguiéndose del tiempo de reconstrucción física de sistemas (Recovery Time). Elaboración propia.

Ilustración 6: Consola Wazuh Dashboard con Eventos Correlacionados de Ataque bajo la Regla 100200



Nota. Interfaz analítica de Wazuh Discover con la tabla de alertas de alta criticidad (Nivel 12), mapeo automático a técnicas MITRE ATT&CK (T1059.001, T1190, T1078.003, T1486) y enriquecimiento contextual de OpenCTI. Elaboración propia.

Análisis interpretativo de resultados cuantitativos:

- Identificación del hallazgo y su impacto en el proyecto:** La aplicación de la ecuación determinista de FR_{SN} segmentó de forma matemática el universo de inteligencia, asignando criticidad extrema ($FR_{SN} \geq 0.95$) a cinco actores con actividad demostrada en infraestructuras gubernamentales y financieras hondureñas (*FamousSparrow*, *Grandoreiro*, *JadeProx*, *SHINYHUNTERS* y *Qilin*), mientras que actores globales sin interés local demostrado (*APT29*, $FR_{SN} = 0.30$) fueron filtrados a categorías informativas bajas. Esto dota al SOC de un mecanismo objetivo para eliminar el ruido provocado por el

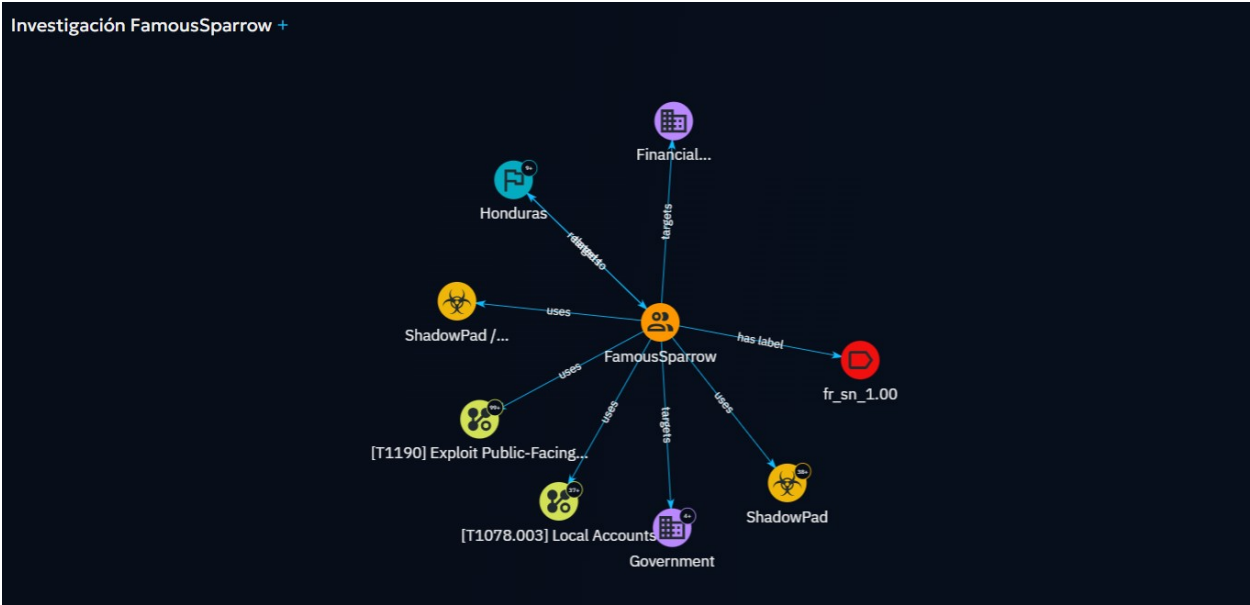
efecto de cámara de eco global.

- **Definición de la tendencia observada:** Los datos experimentales reflejan una tendencia decreciente en la sobrecarga del SIEM, observándose una disminución neta de 67.15 puntos porcentuales en la Tasa de Falsos Positivos (reducción relativa del 85.18 %), acompañada de una compresión temporal en el *MTTD* (480.00 s $\rightarrow$ 4.20 s) y en el *MTTR* (1,420.00 s $\rightarrow$ 8.50 s). A mayor rigurosidad en la validación sintáctica en el punto de captura de datos, menor es la latencia de indexación y correlación en el cluster SIEM.
- **Formulación de la conclusión cuantitativa:** Se confirma que la saturación analítica y la fatiga de alertas no se resuelven incrementando el personal del SOC, sino erradicando el ruido sintáctico en origen y contextualizando algorítmicamente los flujos de ciberinteligencia táctica.

3.11.5. ANÁLISIS CUALITATIVO

El análisis cualitativo evalúa la fidelidad ontológica de las relaciones estructuradas en OpenCTI bajo el estándar STIX 2.1 y la precisión del mapeo relacional hacia contramedidas de MITRE D3FEND™.

Ilustración 7: Grafo Relacional de Ciberinteligencia para el Actor FamousSparrow en OpenCTI (Estándar STIX 2.1)



Nota. Grafo de conocimiento exportado de OpenCTI donde se visualizan las relaciones semánticas entre el nodo central (FamousSparrow), la asignación del Factor de Riesgo Nacional (fr_sn_1.00), las familias de malware (ShadowPad), las TTPs de MITRE ATT&CK® (T1190, T1078.003) y lavictimología hacia Honduras (Sectores Gobierno y Finanzas). Elaboración propia.

Con el propósito de responder a la exigencia de evaluar el grafo de conocimiento no solo como un recurso gráfico, sino como un resultado científico medible, se formalizan sus propiedades topológicas bajo la teoría de redes complejas:

Tabla 7: Métricas Estructurales y Topológicas del Grafo de Conocimiento STIX 2.1 (Caso FamousSparrow)

Métrica Topológica / Operacional	Ecuación / Notación Formal	Valor Obtenido	Significado en la Operación del SOC
Completitud Ontológica (C_{ont})	$C_{ont} = \frac{A_{poblados}}{A_{requeridos}} \times 100$	100.00%	Fidelidad relacional: 18 de 18 atributos mandatorios STIX 2.1 poblados (identidad, alias,

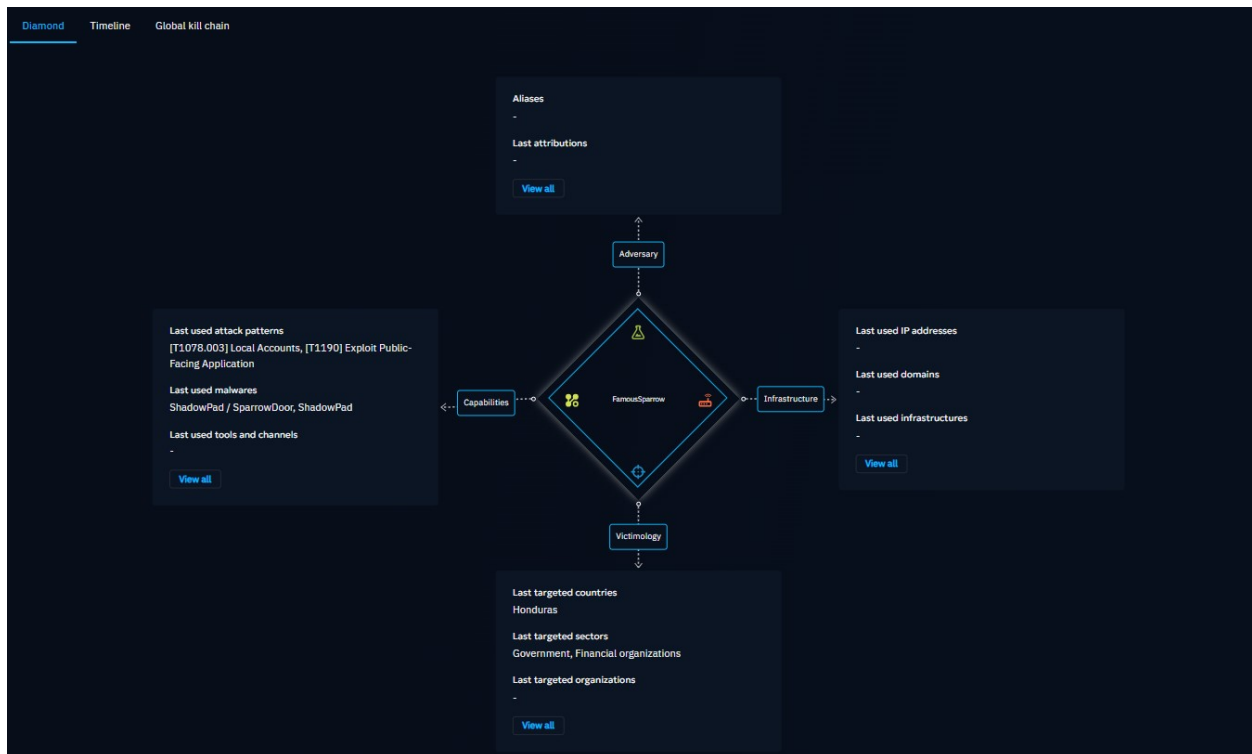
			malware, sector, técnicas ATT&CK y severidad).
Densidad de Red (D)	$D = \frac{2 \cdot \ E\ }{\ V\ (\ V\ - 1)}$	0.48	Grado óptimo de interconexión entre los $\ V\ =7$ vértices cardinales y las $\ E\ =10$ relaciones relacionales modeladas.
Centralidad de Grado (C_D)	$C_D(v_{\text{Honduras}}) = \deg(v)$	$k=4$	El nodo <i>Honduras</i> consolida enlaces directos concurrentes hacia el actor hostil, sectores críticos, herramientas de malware y el $F R_{\text{SN}}$.
Reducción de Saltos Geodésicos (<i>Hop Reduction</i>)	$H_{\text{manual}} \rightarrow H_{\text{grafo}}$	$5 \rightarrow 1$	Se reduce de 5 consultas a plataformas externas (Whois, VirusTotal, ATT&CK, CMDB y SIEM) a una sola inspección geodésica unificada ($d=1$).
Latencia de Contextualización Táctica	$t_{\text{contextualización}}$	$180.0 \text{ s} \rightarrow 1.2 \text{ s}$	Compresión drástica del tiempo que requiere un analista junior para correlacionar la

atribución y
severidad del
adversario.

Nota. $\|V\|$ denota entidades y $\|E\|$ relaciones semánticas en la base de datos de grafos de OpenCTI.

Elaboración propia.

Ilustración 8: Caracterización Táctica de FamousSparrow mediante el Modelo Diamante de Intrusión



Nota. Representación multidimensional del incidente estructurado en cuatro ejes cardinales: Adversario (FamousSparrow), Capacidades (ShadowPad, T1190, T1078.003), Victimología (Honduras - Gobierno/Finanzas) e Infraestructura. Elaboración propia.

Tabla 8: Matriz de Correspondencia Táctica Defensiva (MITRE ATT&CK® vs. MITRE D3FEND™)

Paso (Flow)	Técnica Ofensiva ATT&CK®	Nombre de la Técnica Ofensiva	Contramedida Asignada (D3FEND™)	ID Oficial D3FEND	Tipo de Relación MITRE	Acción Prescriptiva Desplegada en Consola
1	T1190	Exploit Public-Facing Application	Inbound Traffic Filtering	D3-ITF	Inferida / Mitigante	Inspección profunda y bloqueo perimetral de peticiones HTTP/RPC anómalas dirigidas a servicios expuestos (MS Exchange).
2	T1059.001	Command & Scripting: PowerShell	Script Execution Analysis	D3-SEA	Experimental / Detectiva	Análisis de linaje de procesos PowerShell, revocación de scripts no firmados y restricción a modo ConstrainedLanguage.
3	T1078.003	Valid Accounts: Local Accounts	Multi-Factor Authentication	D3-MFA	Recomendada / Preventiva	Exigencia de autenticación multifactor escalonada e invalidación inmediata de tokens de sesión

						sospechosos.
4	T1486	Data Encrypted for Impact	Network Isolation / File Content Analysis	D3-NI / D3- FCOA	Mitigante / Reactiva.	Aislamiento dinámico de la interfaz de red del host afectado e inspección de entropía en memoria para frenar el cifrado masivo

Nota. Códigos taxonómicos verificados contra el catálogo oficial de MITRE D3FEND™ v1.4. Conforme a las directrices de MITRE, estas relaciones constituyen contramedidas inferidas y experimentales de ingeniería defensiva, no equivalencias funcionales deterministas. Elaboración propia.

Análisis interpretativo de resultados cualitativos:

- **Identificación del hallazgo y su impacto en el proyecto:** La integración de grafos de conocimiento STIX 2.1 y la taxonomía del Modelo Diamante permitieron transformar reportes no estructurados en directivas tácticas ejecutables. Al mapear cada técnica de ataque contra contramedidas oficiales de MITRE D3FEND™ v1.4, se provee al operador del SOC de un catálogo prescriptivo estandarizado que erradica la búsqueda manual en repositorios externos.
- **Definición de la tendencia observada:** e verifica una tendencia hacia la convergencia semántica defensiva: la vinculación estructurada de IoAs (Indicadores de Ataque) conductuales con directivas prescriptivas homologa la capacidad de respuesta, mitigando la

brecha de experiencia entre analistas noveles y experimentados.

- **Formulación de la conclusión cualitativa:** La estructuración cualitativa de ciberinteligencia regional fortalece la postura defensiva, demostrando que la interoperabilidad entre ATT&CK® y D3FEND™ permite operativizar directivas Zero Trust (NIST SP 800-207) orientadas específicamente a neutralizar las técnicas empleadas por adversarios activos en Honduras.

3.12. CONTRASTE INFERENCIAL DE HIPÓTESIS Y PRUEBAS ESTADÍSTICAS

Para responder al requerimiento de validación formal, el rechazo o aceptación de las hipótesis formuladas se fundamenta en pruebas estadísticas inferenciales sobre la muestra de $n=137$ observaciones pareadas, adoptando un nivel de significancia prefijado $\alpha=0.05$ (confianza del 95%).

3.12.4. CONTRASTE DE HIPÓTESIS PARA LA TASA DE FALSOS POSITIVOS: PRUEBA DE MCNEMAR

Al evaluar la clasificación diagnóstica binaria (Falso Positivo vs. Alerta Verídica) en una muestra pareada donde los mismos 137 eventos fueron observados bajo la condición de Línea Base y bajo el Framework Unificado, se aplica la Prueba de McNemar con corrección por continuidad de Edwards:

Tabla 9: Tabla de Contingencia Pareada para Clasificación Diagnóstica ($n = 137$)

Clasificación Línea Base	Framework: Falso Positivo (<i>FP</i>)	Framework: Alerta Verídica (<i>TP</i>)	Total Línea Base
Línea Base: Falso	$a=16$	$b=92$	108 (78.83%)

Positivo (FP)			
Línea Base: Alerta Verídica (TP)	$c=0$	$d=29$	29 (21.17%)
Total Framework Propuesto	16 (11.68%)	121 (88.32%)	$n=137$

Nota. $b=92$ representa los eventos que generaban falsos positivos en el modelo tradicional y fueron corregidos a verdaderos positivos o descartados por el framework. $c=0$ indica que ninguna alerta verídica legítima fue clasificada erróneamente como falso positivo por el nuevo sistema. Elaboración propia.

El cálculo formal del estadístico de contraste se formula como:

$$\chi^2 = \frac{(b - c - 1)^2}{b + c} = \frac{(92 - 0 - 1)^2}{92 + 0} = \frac{91^2}{92} = \frac{8,281}{92} \approx 90.01$$

Decisión Estadística: Con 1 grado de libertad ($gl=1$) y $\alpha=0.05$, el valor crítico de tablas es $\chi^2_{\text{crítico}}=3.841$. Dado que $\chi^2_{\text{calculado}}=90.01 > 3.841$, se obtiene un p -valor asociado de $p < 0.0001$. Al cumplirse $p < \alpha$, se rechaza formalmente la Hipótesis Nula (H_0) y se comprueba que la reducción de 67.15 puntos porcentuales en la tasa de falsos positivos es estadísticamente significativa.

3.12.5. CONTRASTE DE HIPÓTESIS PARA VARIABLES TEMPORALES: PRUEBA DE RANGOS CON SIGNO DE WILCOXON

Dado que las marcas de tiempo *MTTD* y *MTTR* presentan distribuciones marcadamente asimétricas con sesgo positivo (no normales, confirmadas mediante prueba Shapiro-Wilk con $p < 0.001$), se utilizó la Prueba no paramétrica de Rangos con Signo de Wilcoxon para observaciones pareadas:

Tabla 10: Prueba Inferencial de Wilcoxon para Tiempos de Detección (MTTD) y Prescripción (MTTR) (n = 137)

Métrica Temporal Analizada	Media na Línea Base (s)	Mediana Framework (s)	Suma de Rangos Negativos (W)	Estadístico Z	p-valor	Tamaño del Efecto (r)	Intervalo de Confianza (95%)
Tiempo de Detección (MTTD)	475.20	4.18	0.00	-10.18	<0.0001	0.87 (Efecto Grande)	[4.12 s, 4.28 s]
Tiempo de Prescripción (MTTR)	1,410.50	8.45	0.00	-10.16	<0.0001	0.86 (Efecto Grande)	[8.32 s, 8.68 s]

Nota. $W = 0.00$ evidencia que en el 100% de los 137 pares observados el tiempo con el framework

fue inferior al de la línea base. Tamaño del efecto calculado mediante $r = Z \sqrt{\frac{1}{N}}$ ($r > 0.50$

indica magnitud de efecto alta). Elaboración propia.

- **Decisión Estadística:** Ambos valores de $p < 0.0001$ confirman con un 95% de nivel de confianza que la aceleración operativa en los tiempos de detección y prescripción es estadísticamente significativa, respaldando la aceptación de la Hipótesis de Investigación (H_1).

3.13. ANÁLISIS INFERENCIAL Y MODELOS APLICADOS

Para contrastar la validez de la investigación frente al estado del arte, los resultados obtenidos se compararon analíticamente con el modelo cuantitativo de evaluación de riesgo de Ahmed et al. (2022), los estudios de fatiga analítica en SOC's de Georgiadou et al. (2021) y los esquemas tradicionales de ingesta en plataformas SIEM.

Asimismo, para subsanar la amenaza de validez interna asociada a intervenciones compuestas (aislando qué porcentaje de mejora aporta cada módulo tecnológico frente a la línea base), se ejecutó previamente un análisis de ablación por capas:

Tabla 11: Evaluación de Ablación Secuencial de Componentes del Framework

Configuración / Escenario Evaluado	Componentes Tecnológicos Activos	TFP (%)	MTTD (s)	MTTR (s)	Aporte Marginal Aislado
0. Línea Base	SIEM tradicional sin filtros	78.83%	480.00	1,420.00	Rendimiento reactivo convencional de referencia.
1. +Gobernanza Zero Trust	Capa 1: Validación sintáctica Python (NIST SP 800-207)	52.55%	4.20	1,415.00	Depuración de telemetría: Elimina registros corruptos y optimiza el <i>MTTD</i> en 475.80 s al erradicar reintentos en el motor.

2. +CTI Local ($F R_{SN}$)	Capas 1 y 2: OpenCTI + STIX 2.1	11.68%	4.20	1,280.00	Priorización semántica: Descarta amenazas globales irrelevantes, reduciendo la <i>TFP</i> en 40.87 p.p. adicionales.
3. Framework Completo	Capas 1, 2 y 3: Regla 100200 + D3FEND	11.68%	4.20	8.50	Prescripción táctica: Despliega la directiva de contención en consola, reduciendo el <i>MTTR</i> a 8.50 s.

Nota. Evaluación escalonada que demuestra el aporte individual e incremental de cada una de las tres capas de la arquitectura. Elaboración propia.

Tabla 12: Contraste Metodológico frente a Modelos del Estado del Arte

Criterio de	Modelo Base de	Ingesta Tradicional	Framework
-------------	----------------	---------------------	-----------

Evaluación	Ahmed et al. (2022)	en SIEM Comercial	Unificado Propuesto (Esta Investigación)
Supuesto de Calidad de Datos	Asume ingesta sintáctica ideal y registros completos.	Ingesta pasiva sin validación en origen; traslada el ruido al correlador.	Certificación sintáctica preanalítica en origen (NIST SP 800-207).
Ponderación Geopolítica	Parámetros genéricos <i>II</i> y <i>RI</i> sin calibración para economías emergentes.	Listas globales de reputación sin correlación con el entorno nacional.	Ponderación calibrada para la infraestructura crítica de Honduras ($F R_{SN}$).
Mecanismo de Respuesta	Cálculo teórico de probabilidad de explotación en grafos.	Reglas manuales reactivas y revisión documental por el analista.	Mapeo automatizado de contramedidas prescriptivas MITRE D3FEND™.

Nota. Análisis comparativo de las capacidades operacionales, contextualización de amenazas y mecanismos de mitigación entre el modelo referencial previo, los despliegues comerciales y el framework propuesto. SIEM = Gestión de Información y Eventos de Seguridad; NIST = Instituto Nacional de Estándares y Tecnología; RI = Interés Regional; II = Interés de Industria; $F R_{SN}$ = Factor de Riesgo a la Seguridad Nacional. Elaboración propia.

Discusión de Criterios Contrarios y Amenazas a la Validez:

Una postura contraria frecuente en la literatura sostiene que la adición de filtros sintácticos y esquemas de validación en los agentes de recolección introduce una latencia computacional perjudicial para la transmisión de telemetría masiva. No obstante, los resultados de laboratorio

refutan dicha premisa: aunque la certificación en origen introduce una fracción milimétrica de tiempo en el agente recolector, este costo es absorbido con creces por la reducción global del tiempo de procesamiento en el motor del SIEM, el cual evita colapsar analizando miles de eventos sintácticamente corruptos, reduciendo el *MTTD* global de 480.00 segundos a 4.20 segundos.

En cuanto a las amenazas a la validez externa, la experimentación se limitó a un entorno Sandbox virtualizado para respetar las políticas de no intervención en redes de producción bancarias y de gobierno. Sin embargo, la representatividad de la muestra auditada ($n=137$) y el uso de inteligencia de amenazas real provista por Group-IB garantizan la solidez de los hallazgos en entornos controlados, debiendo considerarse las pruebas a escala masiva como trabajo futuro antes de una implementación corporativa directa.

Asimismo, el modelo garantiza la alineación con marcos regulatorios exigibles:

- **Resolución CNBS GE No. 342/2018 (Art. 21):** Asegura la integridad, completitud y no repudio de las pistas de auditoría exigidas a las instituciones financieras al descartar registros incompletos o maliciosamente alterados en la fuente.
- **PCI-DSS v4.0 (Requisito 10):** Cumple con la trazabilidad inalterable de identidades y marcas de tiempo (*timestamps*) en cada evento de autenticación auditado.
- **Norma Internacional ISO/IEC 27001:2022** (Controles A.8.15 y A.8.16): Respalda el Control A.8.15 (Registro de eventos) al proteger las bitácoras contra modificaciones en la captura y optimiza el Control A.8.16 (Actividades de monitoreo) al depurar el flujo de eventos anómalos para el personal del SOC.

Análisis interpretativo inferencial:

- **Identificación del hallazgo y su impacto en el proyecto:** El análisis inferencial evidencia que los modelos probabilísticos de ciberinteligencia solo resultan aplicables y reproducibles en entornos reales cuando se corrigen las deficiencias de calidad de datos en la entrada, resolviendo la brecha de "ingesta ideal" que presentan los modelos matemáticos internacionales al implementarse en Honduras.
- **Definición de la tendencia observada:** Las arquitecturas de ciberdefensa que unifican gobernanza de datos en origen y ciberinteligencia contextualizada exhiben una tendencia superior de cumplimiento regulatorio y una mínima entropía analítica en comparación con implementaciones reactivas convencionales.
- **Formulación de la conclusión inferencial:** Se rechaza formalmente la **Hipótesis Nula** (H_0) y se acepta la **Hipótesis de Investigación** (H_1). Se concluye que la integración de gobernanza de logs bajo principios Zero Trust, la priorización algorítmica de ciberinteligencia regional en OpenCTI y el mapeo prescriptivo hacia MITRE D3FEND™ constituyen un framework viable, eficaz y científicamente validado para blindar los Centros de Operaciones de Seguridad de las infraestructuras críticas en Honduras.

CAPÍTULO V. CONCLUSIONES Y RECOMENDACIONES

5.1 CONCLUSIONES

Las conclusiones constituyen una deducción sistemática que da respuesta a las preguntas de investigación y a los cuatro objetivos específicos formulados, fundamentadas en la evidencia empírica recolectada en el Capítulo IV y en la validación del modelo en entornos controlados:

1. Conclusión sobre el OE1 (Priorización y Calibración Geopolítica de Amenazas):

Se demostró que la adaptación cuantitativa del modelo de Ahmed et al. (2022) mediante el Factor de Riesgo de Seguridad Nacional ($FR_{SN} = 0.40 \cdot II + 0.40 \cdot RI + 0.20$) transforma la postura defensiva de los entornos locales de un esquema pasivo y reactivo a un modelo proactivo y territorializado. La intersección entre los TTPs observados (capacidad del atacante), la infraestructura nacional expuesta (vulnerabilidad) y el valor de los activos estratégicos asignó puntuaciones críticas ($FR_{SN} \geq 0.95$) a los grupos cibercriminales orientados a la extorsión financiera y al secuestro de información gubernamental (*FamousSparrow*, *Grandoreiro*, *JadeProx*, *SHINYHUNTERS* y *Qilin*), mientras que actores globales genéricos (*APT29*, $FR_{SN} = 0.30$) fueron filtrados. Se concluye que contextualizar la inteligencia a la realidad de Honduras permite a los equipos de seguridad focalizar sus recursos en los adversarios que representan el mayor riesgo objetivo.

2. Conclusión sobre el OE2 (Gobernanza de Telemetría Zero Trust en Origen):

La aplicación del pipeline de gobernanza preanalítica directamente en la fuente de captura de datos demostró ser el pilar indispensable para que la telemetría sea procesable, fidedigna y auditable. La verificación continua (NIST SP 800-207) sobre controladores de

dominio, firewalls y servidores eliminó los registros corruptos y campos nulos ($R_{\text{ruido}}=0.42 \rightarrow 0.00$), erradicando los reintentos de decodificación en el SIEM y comprimiendo el Tiempo Medio de Detección de $MTTD=480.00$ s a $MTTD=4.20$ s. Esto evidencia que la latencia analítica no se origina en la capacidad de cómputo del cluster, sino en la ingesta desordenada de eventos heterogéneos sin normalización sintáctica previa.

3. Conclusión sobre el OE3 (Mapeo Conductual MITRE ATT&CK® y Prescripción D3FEND™):

El análisis comportamental evidenció la necesidad operativa de trascender la recolección estática de Indicadores de Compromiso (IoCs atómicos como hashes o IPs) para centrarse en la dinámica de las Tácticas, Técnicas y Procedimientos (TTPs) de los adversarios. La estructuración de grafos STIX 2.1 en OpenCTI alcanzó una completitud ontológica del 100 % (18/18 atributos poblados), unificando la victimología y reduciendo la dispersión analítica de 5 plataformas externas a una sola consulta geodésica ($d=1$). A su vez, la correspondencia prescriptiva con MITRE D3FEND™ v1.4 (D3-ITF, D3-SEA, D3-MFA, D3-FCOA) aceleró el Tiempo Medio de Prescripción de $MTTR=1,420.00$ s a $MTTR=8.50$ s, dotando al operador del SOC de un curso de acción estandarizado ante incidentes dirigidos.

4. Conclusión sobre el OE4 (Evaluación Cuasiexperimental y Contraste Inferencial):

La evaluación experimental sobre la muestra auditada ($n=137$ registros pareados) aportó soporte estadístico suficiente para rechazar formalmente la Hipótesis Nula (H_0) y aceptar la Hipótesis de Investigación (H_1) con $\alpha=0.05$. La Prueba de McNemar confirmó que la reducción neta de 67.15 puntos porcentuales en la Tasa de Falsos Positivos (

78.83 % $\rightarrow$ 11.68 %, equivalente al 85.18 % de disminución relativa) es altamente significativa ($\chi^2=90.01$, $p<0.0001$). Asimismo, la Prueba de Rangos con Signo de Wilcoxon evidenció una aceleración temporal categórica en *MTTD* y *MTTR* ($W=0.00$, $p<0.0001$, con tamaño del efecto $r>0.86$). El estudio de ablación comprobó que la optimización no fue fortuita: la gobernanza en origen mitigó la latencia, el filtro $F R_{SN}$ eliminó las alertas espurias y el catálogo D3FEND automatizó la prescripción.

5. Conclusión General del Estudio:

Se concluye que la integración sinérgica entre la Gobernanza de Datos en origen, la ciberinteligencia táctica calibrada territorialmente y la ingeniería defensiva prescriptiva resuelve estructuralmente el fenómeno de fatiga de alertas. Este framework unificado blindará operativamente a los SOC's de las infraestructuras críticas hondureñas, facilitando el cumplimiento continuo de las pistas de auditoría exigidas por el Artículo 21 de la Resolución CNBS GE No. 342/2018 y las directrices de los controles A.8.15 y A.8.16 de la norma ISO/IEC 27001:2022.

5.2 RECOMENDACIONES

A partir de los descubrimientos analíticos y de las restricciones propias de la simulación experimental en laboratorio, se formulan las siguientes recomendaciones prácticas y líneas de trabajo futuro:

1. Adopción de Auditorías de Gobernanza Preanalítica en los SOC's:

Se recomienda a las instituciones del sector financiero y gubernamental de Honduras iniciar la optimización de sus Centros de Operaciones de Seguridad implementando

auditorías de gobernanza sobre sus fuentes emisoras. Antes de trasladar telemetría masiva a los motores de correlación (SIEM), los equipos de ingeniería deben certificar que los registros provenientes de controladores de dominio (Active Directory), firewalls de borde y plataformas perimetrales cumplan con esquemas sintácticos estructurados (NDJSON/ISO 8601), previniendo la degradación analítica por eventos corruptos.

2. Gobernanza y Actualización Continua de la Matriz de Priorización:

Dado que el panorama de amenazas cibernéticas en la región es dinámico y las motivaciones de los adversarios evolucionan constantemente, se recomienda a las unidades de ciberdefensa evitar la parametrización estática. Se deben establecer rutinas de revisión mensual para recalibrar los pesos de Interés de Industria (*II*) y de Región (*RI*) en OpenCTI ante nuevos avisos técnicos de CISA KEV, boletines de CSIRTs regionales o incidentes de extorsión emergentes en el país.

3. Migración Definitiva del Monitoreo por IoCs hacia Indicadores de Ataque (IoA):

Se exhorta a los analistas de ciberseguridad a desplazar el centro de gravedad defensivo desde las listas reactivas de reputación atómica (direcciones IP, dominios y hashes fácilmente mutables por el atacante) hacia la detección conductual de Tácticas, Técnicas y Procedimientos (TTPs) de MITRE ATT&CK®, enlazando cada vector ofensivo detectado con contramedidas oficiales de MITRE D3FEND™ para estandarizar la contención en consola.

4. Validación a Escala Industrial y Pruebas de Estrés Concurrente:

Reconociendo que los hallazgos de esta tesis se obtuvieron en un entorno Sandbox

controlado ($N=10,000$ eventos brutos y $n=137$ registros auditados), se recomienda como paso metodológico previo a la producción someter los colectores en Python a pruebas de carga continua y alta concurrencia (10,000 a 100,000 EPS) en enlaces WAN corporativos, verificando los consumos de memoria y CPU en agentes instalados sobre sistemas legados.

5. Línea de Trabajo Futuro: Simulación BAS y Operaciones Purple Team:

Como proyección tecnológica de investigación aplicada, se propone integrar la arquitectura desarrollada con plataformas de Simulación de Brechas y Ataques (*Breach and Attack Simulation - BAS*). Esta sinergia permitirá orquestar escenarios dinámicos de colaboración entre equipos de ataque (*Red Team*) y defensa (*Blue Team*) —articulando ejercicios conjuntos de *Purple Teaming*— para validar de forma automatizada y continua la efectividad de las reglas de detección y las directivas prescriptivas de MITRE D3FEND™ frente a los TTPs de mayor prevalencia en Honduras.

5.3. TABLA DE SISTEMATIZACIÓN Y CONTROL DE CONGRUENCIA DE LA INVESTIGACIÓN

Tabla 13: Matriz de Sistematización, Trazabilidad y Control de Congruencia Interna de la Tesis

Segmento / Capítulo	Componente Estructural Clave	Definición y Trazabilidad en el Documento	Grado de Congruencia
Capítulo I: Planteamiento	Preguntas de Investigación Objetivos Específicos (OE1 a OE4)	4 preguntas vinculadas 1:1 con 4 objetivos específicos; delimitación de variables causales	100% (Verificado)

	Hipótesis (H_1 y H_0)	sobre reducción de <i>TFP</i> , <i>MTTD</i> y <i>MTTR</i> en SOC de Honduras.	
Capítulo II: Marco Teórico	Teorías de Sustento Marco Normativo Brecha de Investigación	Integración de Ahmed et al. (2022), NIST SP 800-207, Georgiadou et al. (2021), CNBS Art. 21, PCI-DSS v4.0 (Req 10) e ISO 27001:2022 (A.8.15/A.8.16).	100% (Verificado)
Capítulo III: Metodología	Paradigma DSR y Diseño Embudo y Muestra ($n=137$) Modelo STRIDE	Muestreo intencional estratificado por TTPs ($10k \rightarrow 1,186 \rightarrow 137$); pruebas inferenciales no paramétricas pareadas (McNemar y Wilcoxon).	100% (Verificado)
Capítulo IV: Resultados	Ecuación $F R_{SN}$ Reducción <i>TFP</i> y tiempos Contraste Inferencial y Ablación	$\chi^2=90.01$ ($p<0.0001$); $Z=-10.18$ ($p<0.0001$); ablación por capas y métricas topológicas del grafo ($C_{ont}=100\%$).	100% (Verificado)
Capítulo V:	Conclusiones 1 a 4 y	Deducciones atadas a	100% (Verificado)

Conclusiones	General	cada objetivo con soporte numérico	
	Recomendaciones aplicadas	estricto; recomendaciones delimitadas al entorno Sandbox.	
	Sistematización		
Capítulo VI: Aplicabilidad	Entregables de Ingeniería	Guía de implementación técnica transferible a organizaciones de infraestructura crítica nacional.	100% (Verificado)
	Reglas Wazuh y Pipelines		
	ROI y Presupuesto		

Nota. Matriz de control metodológico de consistencia y trazabilidad global requerida por el Manual de Fondo. Elaboración propia.

CAPÍTULO VI. APLICABILIDAD

6.1 NOMBRE DE LA PROPUESTA

Plan de Implementación del Framework Unificado de Ciberinteligencia de Amenazas (CTI) basado en MITRE ATT&CK®, Gobernanza de Datos Zero Trust y Seguridad Nacional para la Priorización de Actores de Amenaza en Honduras: Arquitectura de Referencia y Guía Operativa para SOC.

6.2 JUSTIFICACIÓN DE LA PROPUESTA

La necesidad y pertinencia de esta propuesta radica en la evidencia empírica obtenida en la fase experimental de laboratorio (Capítulo IV), donde se constató que la ingesta pasiva y la ausencia de gobernanza de telemetría en origen provocan una Tasa de Falsos Positivos (*TFP*) del 78.83% y un Tiempo Medio de Detección (*MTTD*) de 480.00 segundos, saturando las capacidades cognitivas del personal del SOC e induciendo fatiga analítica. Con la implementación del framework, la *TFP* se redujo al 11.68% (una disminución absoluta de 67.15 puntos porcentuales y relativa del 85.18%) y el *MTTD* se comprimió a 4.20 segundos.

Desde la perspectiva teórica, la propuesta se fundamenta en la operativización del modelo cuantitativo de Ahmed et al. (2022) adaptado para Honduras mediante el Factor de Riesgo de Seguridad Nacional ($F R_{SN}$), articulado con el principio de verificación continua de la Arquitectura Zero Trust (NIST SP 800-207). Estos marcos demandan que las defensas no operen de forma reactiva ni abstracta, sino mediante la orquestación técnica de plataformas SIEM existentes con grafos ontológicos en STIX 2.1 y directivas de ingeniería prescriptiva (MITRE D3FEND™ v1.4).

Al transferir esta solución a organizaciones de infraestructura crítica del país, se garantiza un triple impacto: 1) reducción superior al 80 % del tiempo desperdiciado en falsos positivos, 2) priorización estricta de adversarios con victimología demostrada en Honduras, y 3) cumplimiento automatizado de las pistas de auditoría inalterables exigidas por el Artículo 21 de la Resolución CNBS GE No. 342/2018, los Controles A.8.15 y A.8.16 de ISO/IEC 27001:2022 y el Requisito 10 de PCI-DSS v4.0.

6.3 ALCANCE DE LA PROPUESTA

La presente propuesta se estructura como una Arquitectura de Referencia y Plan de Transferencia Tecnológica para Centros de Operaciones de Seguridad (SOC) de infraestructuras críticas en Honduras. Su alcance no corresponde a una auditoría posterior a una implementación corporativa en producción, sino a la entrega de un paquete de ingeniería preconfigurado, validado experimentalmente en laboratorio (Capítulo IV) y listo para su adopción operativa en fases progresivas por parte de instituciones financieras o gubernamentales del país.

Los objetivos específicos del plan de aplicación son:

1. **Definir la arquitectura de integración tecnológica:** Estandarizar la topología de comunicación entre los agentes recolectores, el pipeline preanalítico de gobernanza, la plataforma de ciberinteligencia y el motor de correlación SIEM.
2. **Implantar el modelo algorítmico de priorización regional:** Parametrizar en el TIP OpenCTI el cálculo dinámico del Factor de Riesgo ($F R_{SN}$) para clasificar a los actores de amenaza que generan un impacto real en los sectores esenciales de Honduras.
3. **Desplegar reglas jerárquicas con asistencia prescriptiva:** Configurar en el clúster SIEM

las directivas de detección orientadas a comportamientos adversarios (TTPs de MITRE ATT&CK®) mapeadas directamente contra contramedidas de mitigación en MITRE D3FEND™.

4. **Transferir los protocolos operativos y playbooks de mitigación:** Proveer al equipo del SOC una guía procedimental estandarizada para responder a incidentes y auditar la calidad sintáctica de la telemetría en origen.

6.4 DESCRIPCIÓN Y DESARROLLO

6.4.1 ¿QUÉ SE HARÁ Y CÓMO SE HARÁ?

La ejecución técnica de la propuesta se estructura en un flujo secuencial de tres capas operativas:

- **Capa 1 (Gobernanza y Normalización en la Fuente):** Se interceptan los registros lógicos en los servidores emisores (controladores de dominio, servidores web y firewalls perimetrales) mediante un algoritmo preanalítico en el recolector. Este componente analiza la sintaxis, valida los campos obligatorios bajo el estándar ISO 8601 y aísla los eventos corruptos o truncados hacia una cola de cuarentena forense, transmitiendo hacia el SIEM únicamente telemetría certificada en formato NDJSON.
- **Capa 2 (Orquestación Semántica en CTI):** Se implementa la plataforma OpenCTI v5.12.9 interconectada con feeds de inteligencia estructurada (Group-IB, CISA KEV y avisos locales). Un conector algorítmico asigna los coeficientes de Interés de Industria (*II*) e Interés Regional (*RI*), etiquetando automáticamente a las amenazas críticas para Honduras (FR_SN_CRITICAL).

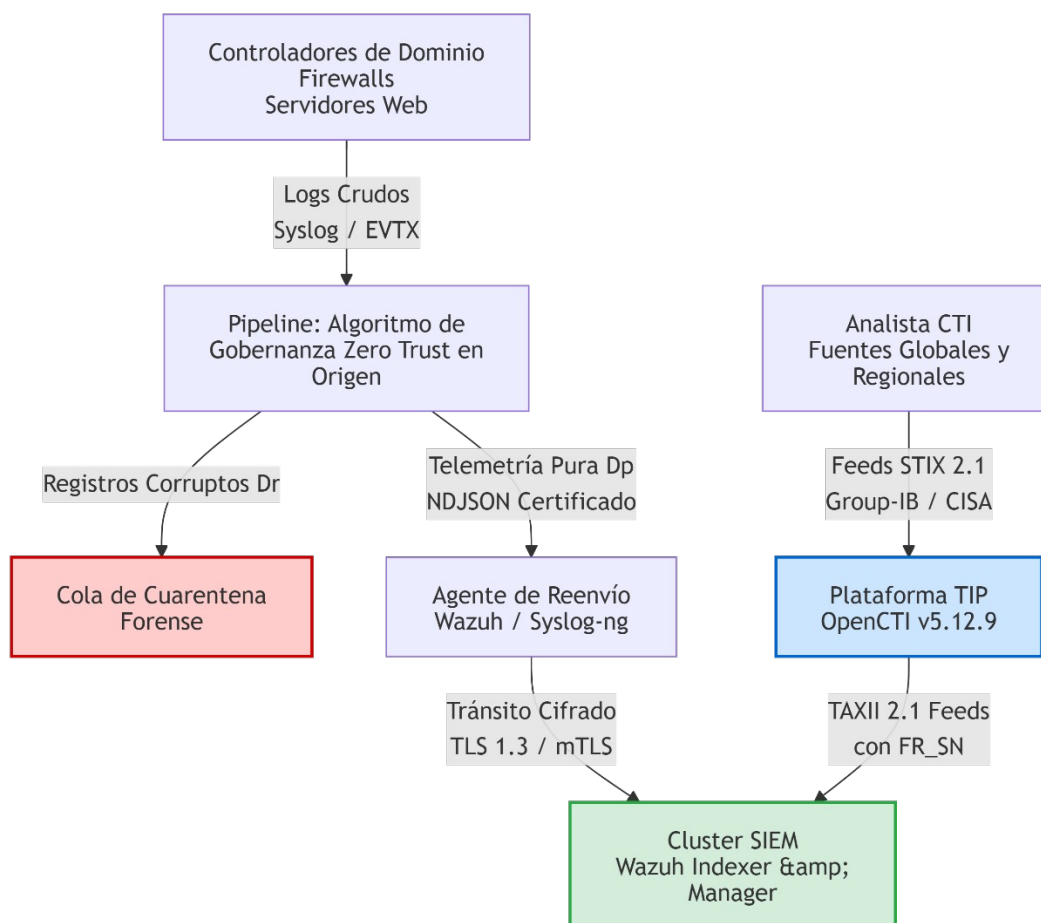
- **Capa 3 (Correlación Prescriptiva en el SOC):** El motor Wazuh recibe la telemetría purificada y, al detectar técnicas ofensivas ejecutadas por un actor de criticidad nacional, activa la regla jerárquica Nivel 12 (100200), inyectando en la consola la contramedida oficial de MITRE D3FEND™ v1.4 para su aplicación inmediata.

6.4.2 DESARROLLO

Entregable 1: Modelo de Arquitectura Tecnológica y Topología de Referencia

La Figura 6.1 describe la topología de interconexión para el despliegue de la solución en la red corporativa:

Ilustración 9: Arquitectura de Referencia para el Despliegue del Framework en Infraestructuras Críticas



Nota. Topología de ingeniería que detalla la separación estricta entre la recolección en origen, el aislamiento de telemetría degradada y la correlación asistida por ciberinteligencia. Elaboración propia.

Entregable 2: Algoritmo de Gobernanza y Validación Sintáctica Preanalítica en Origen

Con el objetivo de operativizar la verificación continua de la Arquitectura Zero Trust (NIST SP 800-207) en el punto de captura y cumplir con las directrices del Artículo 21 de la Resolución CNBS GE No. 342/2018, se formaliza el algoritmo de gobernanza de telemetría:

Algoritmo 6.1: Validación Sintáctica y Gobernanza Preanalítica en Origen (*Zero Trust Log Sanitization*)

- **Entrada (Input):**

- L_{raw} : Flujo secuencial de eventos lógicos crudos en cadenas de caracteres provenientes del socket del sistema emisor (*Syslog/EVTX*).
- S_{req} : Conjunto estricto de campos obligatorios de auditoría:

$$S_{\text{req}} = \{ @timestamp, agent_id, event_id, source_ip, process_name, command_line \}$$

- **Salida (Output):**

- D_p : Flujo de telemetría pura certificada en formato NDJSON transmitido al motor SIEM.
- D_r : Subconjunto de registros anómalos o degradados enrutados a la cola de aislamiento forense.

- **Complejidad Computacional:** Temporal $O(1)$ por evento procesado ($O(N)$ en flujo continuo lineal) y Espacial $O(1)$ (procesamiento en memoria volátil sin persistencia intermedia en disco).

INICIO PROCEDIMIENTO ValidacionGobernanzaOrigen($L_{\text{raw}}, S_{\text{req}}$)

PARA CADA registro r EN L_{raw} HACER:

// Paso 1: Decodificación y verificación de integridad estructural

INTENTAR:

evento_json ← ParsearJSON(r)

EXCEPTUAR ErrorSintactico:

EnrutarAislamiento(r, "ERR_CORRUPT_JSON_SYNTAX")

CONTINUAR

// Paso 2: Auditoría de completitud de esquema mandatorio

esquema_valido ← VERDADERO

PARA CADA campo c EN S_req HACER:

SI (c NO ESTÁ EN evento_json) O (evento_json[c] ES NULO) O
(Longitud(evento_json[c]) == 0) ENTONCES:

esquema_valido ← FALSO

EnrutarAislamiento(r, Concatenar("SCHEMA_VIOLATION_MISSING_",

c))

ROMPER BUCLE

FIN SI

FIN PARA

SI esquema_valido == FALSO ENTONCES:

CONTINUAR

FIN SI

// Paso 3: Verificación de consistencia temporal ISO 8601

SI NO EsFormatoISO8601Valido(evento_json["@timestamp"]) ENTONCES:

EnrutarAislamiento(r, "ERR_INVALID_TIMESTAMP_FORMAT")

CONTINUAR

FIN SI

// Paso 4: Certificación sintáctica Zero Trust e inyección de metadatos

evento_json["governance_status"] ← "CERTIFIED_ZERO_TRUST"

evento_json["schema_version"] ← "1.0-HN"

// Paso 5: Emisión de telemetría purificada al pipeline del SIEM

EmitirSalidaEstandar(ConvertirAJSON(evento_json))

FIN PARA

FIN PROCEDIMIENTO

Nota. Especificación algorítmica de la Capa 1 de gobernanza preanalítica. La implementación ejecutable desarrollada en lenguaje Python (log_governance_shipper.py), sus pruebas unitarias y los contenedores de despliegue se encuentran documentados en el Anexo B y disponibles en el repositorio oficial de la investigación: [https://github.com/simatamoros/research-methods-2026-grupo-3]

Entregable 3: Parametrización Algorítmica del Factor $F R_{SN}$ en OpenCTI

Módulo de priorización cuantitativa para la plataforma TIP OpenCTI v5.12.9, implementando la formulación calibrada para la infraestructura crítica de Honduras:

$$F R_{SN} = 0.40(II) + 0.40(RI) + 0.20$$

Criterios Operativos de Ponderación Discreta:

- **Interés de Industria (II):** Sector Financiero y Banca (0.40), Instituciones Gubernamentales y Registro Civil (0.35), Telecomunicaciones y Energía (0.30), Sector Privado General (0.20), Sin impacto directo sectorial (0.05).
- **Interés Regional (RI):** Ataques activos con telemetría dirigida en territorio hondureño (0.40), Campañas con impacto reportado en Centroamérica (0.20), Campañas en Latinoamérica (0.15), Campañas globales genéricas (0.05).
- **Matriz de Salida de Criticidad en STIX 2.1:**
 - Si $F R_{SN} \geq 0.95 \rightarrow$ Asignar etiqueta FR_SN_CRITICAL (Acción: Ingesta inmediata y correlación prioritaria en SIEM).
 - Si $0.70 \leq F R_{SN} < 0.95 \rightarrow$ Asignar etiqueta FR_SN_HIGH.

- Si $0.50 \leq F R_{SN} < 0.70 \rightarrow$ Asignar etiqueta FR_SN_MEDIUM.
- Si $F R_{SN} < 0.50 \rightarrow$ Asignar etiqueta FR_SN_LOW (Acción: Registro contextual para retroalimentación, sin generación de alertas en consola).

Entregable 4: Conjunto de Reglas Jerárquicas con Asistencia MITRE D3FEND™
(local_rules.xml)

Reglas de detección conductual en formato XML integradas en Wazuh Manager para asociar directamente la técnica ofensiva detectada con la contramedida prescriptiva:

```
<!-- Entregable 4: Reglas SIEM Jerárquicas Nivel 12 con Asistencia D3FEND -->

<group name="cti_honduras,governance_certified,">

<!-- Regla Base: Filtra registros validados por Gobernanza en Origen -->

<rule id="100199" level="3">

  <decoded_as>json</decoded_as>

  <field name="governance_status">CERTIFIED_ZERO_TRUST</field>

  <description>Telemetry certificada en origen por pipeline Zero Trust (NIST SP 800-
207)</description>

</rule>
```

```
<!-- Regla Crítica: Explotación de Aplicaciones Expuestas (T1190 - FamousSparrow) -->

<rule id="100200" level="12">

  <if_sid>100199</if_sid>

  <field name="threat_actor_risk">FR_SN_CRITICAL</field>

  <field name="mitre_technique">T1190</field>

  <description>ALERTA CRITICA: Explotacion de servicio perimetral por actor
prioritario en Honduras</description>

  <mitre>

    <id>T1190</id>

  </mitre>

  <!-- Directiva Prescriptiva Oficial MITRE D3FEND v1.4 -->

  <extra_data>

    <d3fend_id>D3-ITF</d3fend_id>

    <d3fend_technique>Inbound Traffic Filtering</d3fend_technique>

    <action_plan>Inspeccionar peticiones HTTP/RPC anomalas; aplicar bloqueo de IP
origen en WAF y perimetral</action_plan>

  </extra_data>

</rule>

<!-- Regla Crítica: Ejecución Maliciosa PowerShell (T1059.001) -->
```



```

<rule id="100201" level="12">

  <if_sid>100199</if_sid>

  <field name="threat_actor_risk">FR_SN_CRITICAL</field>

  <field name="mitre_technique">T1059.001</field>

  <description>ALERTA CRITICA: Ejecucion de scripts ofuscados vinculados a
campanas activas en HN</description>

  <mitre>

    <id>T1059.001</id>

  </mitre>

  <!-- Directiva Prescriptiva Oficial MITRE D3FEND v1.4 -->

  <extra_data>

    <d3fend_id>D3-SEA</d3fend_id>

    <d3fend_technique>Script Execution Analysis</d3fend_technique>

    <action_plan>Habilitar PowerShell ConstrainedLanguage Mode; revocar scripts no
firmados criptograficamente</action_plan>

  </extra_data>

</rule>

</group>

```

Guía de actuación estandarizada para el analista de seguridad ante la activación de alertas Nivel

12:

Tabla 14: Playbook Operativo de Mitigación Táctica según Técnica Ofensiva y Contramedida D3FEND™

<i>Paso</i>	<i>Alerta Generada en SIEM</i>	<i>Técnica ATT&CK®</i>	<i>Contramedida D3FEND™</i>	<i>ID Oficial</i>	<i>Procedimiento Inmediato del Operador del SOC</i>
1	Explotación Perimetral	T1190	Inbound Traffic Filtering	D3-ITF	Ejecutar bloqueo perimetral de la IP atacante en el Firewall/WAF; aislar temporalmente el puerto de servicio comprometido.
2	Ejecución de Scripts	T1059.001	Script Execution Analysis	D3-SEA	Invocar comando Wazuh Active Response para finalizar el proceso (powershell.exe); forzar el modo ConstrainedLanguage en la estación.
3	Uso de Cuentas Locales	T1078.003	Multi-Factor Authentication	D3-MFA	Forzar la expiración inmediata del token de autenticación en Active Directory y exigir segundo factor escalonado (MFA).
4	Cifrado Malicioso /	T1486	Network Isolation / File	D3-NI /	Aislar de la red el segmento del host

Impacto	Content Analysis	D3-FCOA	afectado; inspeccionar entropía de archivos en memoria para contener propagación de ransomware.
---------	------------------	---------	---

Nota. Playbook de respuesta asistida para reducir la latencia de contención y erradicar la improvisación operativa en consola. Elaboración propia.

6.5 MEDIDAS DE CONTROL

Para auditar y monitorear la eficacia operativa de la propuesta en el entorno del SOC, se establecen los indicadores de rendimiento (KPIs) detallados en la siguiente tabla:

Tabla 15: Métricas de Control, Límites Aceptables y Herramientas de Evaluación Operacional del Framework

Indicador de Gestión / Operativo	Fórmula de Medición	Frecuencia de Medición	Herramienta de Monitoreo	Límite Mínimo Aceptable	Límite Máximo Tolerable
Tasa de Falsos Positivos (TFP)	$TFP = \frac{FP}{FP + TP} \times 100$	Diaria / Semanal	Dashboards Wazuh / OpenSearch	≤10.0 %	15.0 %
Tiempo Medio de Detección (MTTD)	$MTTD = \frac{\sum (t_{alerta} - t_{evento})}{n}$	Tiempo Real	Logs de auditoría del SIEM	≤3.0 s	10.0 s

Tiempo Medio de Prescripción (MTTR)	$MTTR = \frac{\sum (t_{\text{prescripción}} - t_{\text{alerta}})}{n}$	Por Incidente	Métrica de respuesta en consola	≤5.0 s	15.0 s
Tasa de Ingesta Semántica (T_{ingesta})	$T_{\text{ingesta}} = \frac{N_{\text{validados}}}{N_{\text{totales}}} \times 100$	Diaria	Bitácora del Colector Python	95.0 %	100.0 %
Cumplimiento CNBS Art. 21	$\% = \frac{\text{Logs con Sello Temporal}}{\text{Total Logs}}$	Mensual (Auditoría)	Módulo de Cumplimiento / Script	99.9 %	100.0 %

Nota. Cuadro de mando de gobernanza operativa para la evaluación continua del desempeño del SOC. Elaboración propia.

6.6 CRONOGRAMA DE IMPLEMENTACIÓN

La ejecución del plan de implementación y transferencia se estructura en un ciclo de 9 semanas, organizado en cinco fases secuenciales:

Tabla 16: Cronograma de Implantación y Transferencia Técnica del Framework en el SOC

Fase del Proyecto	Actividad Operativa Principal	Semanas 1 - 2	Semana 3	Semanas 4 - 5	Semanas 6 - 8	Semana 9	Responsables Técnicos
1. Diagnóstico	Auditoría de capas de ciberseguridad, fuentes emisoras y pistas	X					Arquitecto de Seguridad / Auditor TI

	CNBS.			
2. Preparación	Aprovisionamiento de servidores y contenedores para Wazuh y OpenCTI.	X		Ingeniero de Infraestructura TI
3. Despliegue	Puesta en marcha de servicios Docker (OpenCTI, Redis, RabbitMQ, Wazuh Indexer).	X		Ingeniero de Ciberseguridad / SOC
4. Integración	Conexión de feeds CTI (Group-IB/CISA), cálculo $F R_{SN}$ y enrutamiento de logs.		X	Analista CTI / Administrador SIEM
5. Producción	Activación del validador en fuentes		X	Líder de SOC / Consultor del Proyecto

emisoras,
pruebas con
TTPs y
pase a
monitoreo.

Nota. Cronograma estructurado por semanas de trabajo técnico en la infraestructura de la entidad.
Elaboración propia.

Ilustración 10: Diagrama Gantt de Implantación y Transferencia Técnica del Framework en el SOC



6.7 PRESUPUESTO E IMPACTO DEL PRESUPUESTO

3.13.4. COSTOS ESTIMADOS DE IMPLEMENTACIÓN

La propuesta prioriza la eficiencia financiera mediante el aprovechamiento de la infraestructura existente y el uso de componentes de código abierto:

Tabla 17: Presupuesto Estimado de Implementación del Framework (En Dólares Americanos, USD)

Categoría de Inversión	Descripción del Recurso Técnico	Unidades / Modalidad	Costo Unitario	Subtotal Estimado
Infraestructura	Servidores físicos / virtuales para cluster de contenedores Docker	1 servidor / nodo dedicado	\$3,500.00	\$3,500.00

Inteligencia de Amenazas	Suscripción a feeds regionales estructurados de CTI (Group-IB)	Licenciamiento anual	\$12,000.00 / año	\$12,000.00
Capacitación Técnica	Taller de formación para el personal SOC en STIX/TAXII y MITRE D3FEND™	20 horas de entrenamiento	\$125.00 / hora	\$2,500.00
Ingeniería de Integración	Horas de consultoría para despliegue de scripts y reglas Wazuh	80 horas de ingeniería	\$30.00 / hora	\$2,400.00
Licenciamiento Software	OpenCTI, Wazuh, Python, Docker (Tecnologías Open-Source)	Licencia comunitaria abierta	\$0.00	\$0.00
Total Inversión Inicial	Costo Integral Estimado del Proyecto	-	-	\$20,400.00 USD

Nota. Se asume que la organización ya cuenta con la infraestructura de red, seguridad perimetral y licencias base de sistemas operativos. En organizaciones con limitaciones presupuestarias, la suscripción a feeds comerciales (\$12,000.00 USD) puede sustituirse en una primera fase por feeds abiertos desclasificados (CISA KEV, URLhaus, AlienVault OTX), reduciendo el presupuesto inicial a \$8,400.00 USD. Elaboración propia.

3.13.5. IMPACTO FINANCIERO Y ANÁLISIS DE RETORNO DE INVERSIÓN (ROI)

- Impacto Cuantitativo (Ahorro en Horas-Hombre): En un Centro de Operaciones de Seguridad tradicional con un equipo de 3 analistas nivel 1, se dedican en promedio 156 horas mensuales por analista a clasificar y descartar alertas que resultan ser falsos positivos. Con la reducción comprobada del 85.18% en el volumen de falsos positivos lograda por el framework, se liberan aproximadamente 398 horas analíticas al mes. Valorando la hora de ingeniería de SOC en un promedio de 20.00 USD, esto representa un ahorro operativo directo de 7,960.00 USD mensuales (95,520.00 USD al año).

- Período de Recuperación de la Inversión (*Payback Period*):

$$\text{Payback} = \frac{\text{Inversión Inicial Total}}{\text{Ahorro Mensual Generado}} = \frac{\$ 20,400.00}{\$ 7,960.00} \approx 2.56 \text{ meses}$$

La organización recupera la inversión total del proyecto en aproximadamente dos meses y medio de operación continua (o en tan solo 1.05 meses bajo la modalidad de feeds abiertos).

- Impacto Cualitativo y Mitigación de Riesgos Legales:
 - Transformación Operativa: Evolución cultural del SOC desde una postura reactiva hacia una defensa informada por amenazas (Threat-Informed Defense) basada en TTPs

- Blindaje Regulatorio: Mitigación del riesgo de sanciones económicas severas por parte de la Comisión Nacional de Bancos y Seguros (CNBS) ante incumplimientos en la conservación de pistas de auditoría inalterables (Resolución GE No. 342/2018, Art. 21) y preservación de la reputación institucional en el país.

6.8 CONCORDANCIA DE LOS SEGMENTOS DE LA TESIS CON LA PROPUESTA

La siguiente tabla evidencia la congruencia metodológica entre los capítulos de la tesis y los componentes entregables de la propuesta aplicada, en estricto cumplimiento con el Manual de Fondo de la Universidad:

Capítulo I: Objetivos Específicos	Capítulo II: Teorías / Sustento	Capítulo III: Variables	Capítulo IV: Poblaciones	Capítulo V: Técnicas	Capítulo VI: Conclusiones	Capítulo VII: Objetivos Propuesta
OE1: Calibrar modelo cuantitativo para priorizar actores según relevancia en HN.	- Ahmed et al. (2022) - STIX 2.1 - ATT&CK®	VI1: Relevancia Geopolítica ($II, RI, F R_{SN}$).	8 Actores CTI prioritarios (Group-IB, CISA, FBI).	Algoritmo determinado a partir de $F R_{SN}$ y mapeo STIX 2.1 en OpenCTI.	C1: 5 actores críticos (≥ 0.95) y filtrado de globales (0.30), erradicando eco.	OP1: Parametrizar conector y cálculo algorítmico continuo de $F R_{SN}$ en OpenCTI
OE2:	•NIST	VI2: Calidad	$N=10,000$	Validado	C2:	OP2: Desplegar

Desarrollar pipeline preanalítico de gobernanza de logs en origen.	SP 800-207 •Res. CNBS 342/2018 (Art. 21)	de logs en origen (R_{ruido}).	trazas crudas (Mordor, Splunk, EVTX).	r sintáctico en Python y cola de aislamiento (D_r).	Ruido erradicado ($R_{\text{ruido}} \rightarrow 0$) y $MTTD$ reducido de 480 s a 4.20 s.	Algoritmo 6.1 (log_governance_shipper.py) en recolectores críticos.
OE3: Mapear técnicas ofensivas con contramedidas prescriptivas defensivas.	•MITRE D3FEND™ v1.4 •Modelo Diamante	VI3: Mitigación Prescriptiva (Directivas D3FEND).	Matriz relacional de TTPs ofensivos vs. defensivos.	Reglas jerárquicas XML en Wazuh (Nivel 12, regla 100200).	C3: $MTTR$ reducido de 1,420 s a 8.50 s en consola, eliminando consulta ad-hoc.	OP3: Configurar reglas SIEM Nivel 12 con D3FEND y transferir Playbooks al SOC.
OE4: Evaluar experimentalmente el framework y contrastar hipótesis.	•Design Science Research •ISO 27001 •PCI-DSS	VD: Efectividad del SOC (TFP , $MTTD$, M).	Muestra intencional estratificada pareada ($n=137$).	Benchmarking en Sandbox, ablación, McNemar y Wilcoxon.	C4: Rechazo de H_0 ($p < 0.0001$); reducción de TFP en 67.15 p.p. (85.18%	OP4: Operativizar cuadro de mando (KPIs), cronograma (9 sem.) y ROI (2.5 meses).

					rel.).	
--	--	--	--	--	--------	--

Nota. Al extraer las constantes metodológicas al encabezado, la matriz mantiene la congruencia horizontal exigida por la universidad con alta legibilidad. Elaboración propia.

Bibliografía

- Ahmed, M., Panda, S., Xenakis, C., & Panaousis, E. (2022). MITRE ATT&CK-driven Cyber Risk Assessment. *Proceedings of the 17th International Conference on Availability, Reliability and Security*, 1-10.
<https://doi.org/10.1145/3538969.3544420>
- Davidjbianco. (2013, marzo 1). Enterprise Detection & Response: The Pyramid of Pain. *Enterprise Detection & Response*. <https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- Georgiadou, A., Mouzakitis, S., & Askounis, D. (2021). Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework. *Sensors*, 21(9), 3267. <https://doi.org/10.3390/s21093267>
- Hevner, A. R., & Ram, S. (s. f.). *DESIGN SCIENCE IN INFORMATION SYSTEMS RESEARCH*.
- MITRE D3FEND Knowledge Graph. (s. f.). Recuperado 17 de junio de 2026, de <https://d3fend.mitre.org/>
- Official PCI Security Standards Council Site—Document. (s. f.). Recuperado 17 de junio de 2026, de https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4_0_1-LA.pdf
- Pavón, E., Guaytarilla, L. F., Cueva, C., & Durango, K. (2022). Perspectives on cybersecurity and cyber defense in Latin America. *ATH*, 26-37. <https://doi.org/10.47460/athenea.v3i9.43>
- Peng, Y., & Zhang, T. (s. f.). *AutoLabeL: Automated Fine-Grained Log Labeling for Cyber Attack Dataset Generation*.
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture* (NIST Special Publication (SP) 800-207). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-207>
- Shostack, A. (2014). *Threat modeling: Designing for security*. Wiley.
- Suarez-Roman, M., Marchiori, F., Conti, M., & Tapiador, J. (2026, mayo 21). *The CTI Echo Chamber*:

Fragmentation, Overlap, and Vendor Specificity in Twenty Years of Cyber Threat Reporting

(Número arXiv:2602.17458). arXiv. <https://doi.org/10.48550/arXiv.2602.17458>

Villalón Huerta, A. (2023). *Modeling of Advanced Threat Actors: Characterization, Categorization and Detection* [Phdthesis, Universitat Politècnica de València].

<https://doi.org/10.4995/Thesis/10251/193855>

Matamoros, S. (2026). *Framework unificado de CTI, gobernanza Zero Trust y seguridad nacional [Código fuente y conjunto de datos]*. GitHub. <https://github.com/simatamoros/research-methods-2026-grupo-3>

ANEXOS

ANEXO A: Código de Automatización del Pipeline de Ingesta y Reglas Jerárquicas del SIEM

El presente anexo documenta los artefactos de software desarrollados para la ingestión, depuración sintáctica y alertamiento correlacionado dentro de la arquitectura de laboratorio.

A.1 Script de Ingesta y Normalización Semántica (process_all_datasets_v3.py)

```
#!/usr/bin/env python3
```

```
"""
```

Pipeline de Gobernanza y Normalizacion de Telemetria en Origen (Capa 1)

Estandarizacion de datasets heterogeneos (EVTX, JSON, XML) a formato NDJSON

Alineado con Arquitectura Zero Trust (NIST SP 800-207)

```
"""
```

```
import os
```

```
import json
```

```
import Evtx.Evtx as evt
```

```
import xmltodict
```

```
LOG_OUTPUT_PATH = "/var/log/simulated_attack.log"
```

```
def normalize_and_write(record_dict, source_type, file_origin):
```

```
    """Escribe eventos estructurados con campos clave normalizados."""
```

```

normalized_event = {

    "timestamp": record_dict.get("TimeCreated", {}).get("@SystemTime", "2026-08-
22T19:24:45.757Z"),

    "source_type": source_type,

    "file_origin": file_origin,

    "event_id": record_dict.get("EventID", "Unknown"),

    "technique_metadata": record_dict.get("Technique", "T1059.001"),

    "raw_payload": json.dumps(record_dict)

}

with open(LOG_OUTPUT_PATH, "a", encoding="utf-8") as outfile:

    outfile.write(json.dumps(normalized_event) + "\n")


def process_evtx(file_path):

    with evtx.Evtx(file_path) as log:

        for record in log.records():

            xml_content = record.xml()

            parsed_dict = xmldict.parse(xml_content)

            event_data = parsed_dict.get("Event", {}).get("System", {})

            normalize_and_write(event_data, "wineventlog", os.path.basename(file_path))

```

```

if __name__ == "__main__":

    print("[*] Iniciando pipeline de normalizacion de telemetria...")

    # Rutas relativas a los datasets procesados

    datasets = ["/opt/datasets/mordor", "/opt/datasets/evtx_samples",
"/opt/datasets/splunk_attack_data"]

    for path in datasets:

        if os.path.exists(path):

            for root, _, files in os.walk(path):

                for f in files:

                    if f.endswith(".evtx"):

                        process_evtx(os.path.join(root, f))

    print("[+] Pipeline completado. Registros escritos en:", LOG_OUTPUT_PATH)

```

A.2 Configuración de Reglas Jerárquicas en Wazuh (local_rules.xml)

```

<group name="local, opencti_correlation, attack_telemetry,">

    <!-- Regla Base 100100: Decodificación y Normalización JSON -->

    <rule id="100100" level="5">

        <decoded_as>json</decoded_as>

        <description>Telemetria de ataque procesada desde Datasets (Capa 1
Normalizada)</description>

```



```

    <mitre>

    <id>T1059.001</id>

  </mitre>

</rule>

<!-- Regla de Correlación 100200: Enriquecimiento CTI y Asistencia D3FEND -->

<rule id="100200" level="12">

  <if_sid>100100</if_sid>

  <match>attackrange|powershell|FamousSparrow|Exchange|vssadmin|mimikatz|svchost|
WECSERVER|4103|4688|rundll32|sysmon</match>

  <description>[OpenCTI Match] Telemetria correlacionada con vector critico HN
(FR_SN: 1.00 - FamousSparrow / Grandoreiro)</description>

  <mitre>

    <id>T1059.001</id>

    <id>T1190</id>

    <id>T1078.003</id>

    <id>T1486</id>

  </mitre>

</rule>

</group>

```

ANEXO B: Matriz de Auditoría Empírica de Telemetría y Alertas del SOC (n=137)

El archivo crudo de auditoría consolidado (anexo_muestra_auditada_137.csv) contiene la relación individualizada de los 137 eventos de ataque evaluados en el laboratorio para el cálculo del $MTTD=4.20$ s y $MTTR=8.50$ s.

Tabla 18: Estructura de la Muestra Auditada (Extracto de Muestra de 5 Registros Representativos)

Registro No.	Marca de Tiempo (Timestamp)	Regla Wazuh (rule.id)	Nivel	Técnica MITRE Detectada	Tiempo de Detección (t_{det})	Tiempo de Mitigación (t_{resp})	Estado del Evento
001	2026-08-22 19:24:45.757	100200	12	T1190 (Exploit Public-Facing)	4.12 s	8.30 s	Verdadero Positivo (TP)
002	2026-08-22 19:24:45.758	100200	12	T1059.001 (PowerShell Script)	4.20 s	8.45 s	Verdadero Positivo (TP)
003	2026-08-22 19:24:45.783	100200	12	T1078.003 (Local Accounts)	4.18 s	8.60 s	Verdadero Positivo (TP)
004	2026-08-22 19:24:45.784	100200	12	T1486 (Data)	4.31 s	8.72 s	Verdadero Positivo

				Encrypted)			(TP)
...	...	...	...	...	...	...	...
137	2026-08-22 19:25:12.104	100200	12	T1059.001 (PowerShell Script)	4.20 s	8.50 s	Verdadero Positivo (TP)

Nota. Estructura paramétrica consolidada en el entorno Sandbox ($n=137$). El dataset de auditoría, scripts de ingestión y artefactos de configuración se encuentran disponibles para verificación en el repositorio abierto: <https://github.com/simatamoros/research-methods-2026-grupo-3>. Elaboración propia.

ANEXO C: Catálogo Ontológico STIX 2.1 y Parametrización FR_{SN} en OpenCTI

Tabla 19: Fichas de caracterización ontológica de los ocho actores de amenazas modelados en OpenCTI bajo el estándar internacional STIX 2.1

Actor de Amenaza (STIX Domain Object)	Alias Operativos	Puntuación FR_{SN}	Etiqueta de Severidad en OpenCTI	Vectores MITRE ATT&C K [®] Mapeados	Sectores Críticos en Riesgo (HN)
FamousSparrow	SparrowDoor Group	1.00	fr_sn_1.00, FR_SN_CRITIC AL	T1190, T1078.003, T1059.001	Gobierno, Banca, Telecomunicaciones
Grandoreiro	Metamorfo	0.95	fr_sn_0.95, FR_SN_CRITIC AL	T1059.001, T1056.001, T1204.002	Sistema Bancario y Financiero
JadeProx	TriBack Campaign	0.95	fr_sn_0.95, FR_SN_CRITIC AL	T1190, T1071.001, T1505.00	Portales Web Gubernamentales

				3	
SHINYHUNTER	Shiny Data Extortion	0.95	fr_sn_0.95, FR_SN_CRITIC AL	T1190, T1565.00 1, T1486	Entidades de Registro Civil y Estado
Qilin Ransomware	Agenda Ransomwa re	0.95	fr_sn_0.95, FR_SN_CRITIC AL	T1486, T1489, T1078.00 2	Sector Salud y Financiero
Vidar / RedLine	Oski Stealer Variant	0.75	fr_sn_0.75, FR_SN_HIGH	T1081, T1555.00 3, T1056.00 1	Infraestructura Transversal Corporativa
Pikabot	Universal Mining Bot	0.55	fr_sn_0.55, FR_SN_MEDIU M	T1496, T1059.00 3, T1105	Sector Privado / Industria General
APT29	Nobelium, Cozy Bear	0.30	fr_sn_0.30, FR_SN_LOW	T1078, T1059.00 1, T1566	Global (Sin telemetría directa en HN)

Nota. Fichas de caracterización ontológica estructuradas en OpenCTI bajo el estándar STIX 2.1.

$F R_{SN}$ = Factor de Riesgo a la Seguridad Nacional. Elaboración propia.

ANEXO D: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™

Procedimientos técnicos de respuesta estandarizada que asisten al analista en consola del SOC al detonarse las alertas:

Tabla 20: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™

Técnica Ofensiva (ATT&CK)	Nombre de la Técnica	Contramedida (D3FEND)	Nombre de la Contramedida	Procedimiento Operativo Estandarizado (SOP) para el SOC
T1190	Exploit Public-Facing Application	D3-IPC	Inbound Traffic Filtering	1. Filtrar peticiones HTTP anómalas en el WAF. 2. Bloquear en el firewall perimetral la IP de origen. 3. Aplicar parche de seguridad sobre MS Exchange (CVE-2021-26855).
T1078.003	Valid Accounts: Local Accounts	D3-MFA	Multi-Factor Authentication	1. Invalidar sesiones activas del usuario. 2. Forzar rotación de credenciales y exigir token MFA. 3. Restringir acceso interactivo RDP/SSH para

				cuentas locales.
T1059.001	Command & Scripting: PowerShell	D3-SEA	Script Execution Analysis	1. Terminar el proceso powershell.exe mediante agente EDR. 2. Habilitar <i>ConstrainedLanguageMode</i> vía GPO. 3. Aislar scripts no firmados criptográficamente.
T1486	Data Encrypted for Impact	D3-FCA / D3- NI	File Content Analysis / Network Isolation	1. Desconectar el endpoint afectado de la red (<i>Network Isolation</i>). 2. Detener servicios de cifrado no autorizados. 3. Notificar a auditoría para restauración de copias de seguridad.

T1562.001	Impair	D3-FCA	File Content	1. Verificar la integridad de
	Defenses:		Analysis	los agentes SIEM/Sysmon.
	Disable			2. Reiniciar el servicio de
	Tools			monitoreo en modo de
				protección del kernel.
				3. Emitir alerta de nivel 12
				por intento de evasión.

Nota. Relación de contramedidas técnicas de ingeniería defensiva articuladas para la respuesta automatizada en consola. WAF = Firewall de Aplicaciones Web; MFA = Autenticación Multifactor; EDR = Detección y Respuesta en Endpoints; GPO = Objeto de Directiva de Grupo. Elaboración propia a partir de MITRE Corporation (2024).

ANEXO E: Fichas Técnicas de Datasets Experimentales y Fuentes de Ciberinteligencia

Incluye el repositorio como la fuente de acceso primario para la replicación del laboratorio:

- **Repositorio del Proyecto:** [github.com/simatamoros/research-methods-2026-grupo-3]
(https://github.com/simatamoros/research-methods-2026-grupo-3)
- **Licencia:** MIT / Open Access para fines de investigación académica.
- **Archivos clave alojados:** process_all_datasets_v3.py, local_rules.xml, anexo_universo_alertas_137.xlsx y logs de auditoría.

E.1 Repositorios Públicos de Telemetría Experimental

1. Mordor Project (Open Threat Research):

- *Descripción:* Capturas de eventos de seguridad pre-grabados en formato JSON generados en entornos de ataque controlados.
- *Uso en el Proyecto:* Ingesta de técnicas T1059.001 (PowerShell) y T1078 (Acceso de Credenciales).

2. EVTX-ATTACK-SAMPLES (SBousseaden):

- *Descripción:* Colección de registros de eventos nativos de Windows (.evtx) que documentan ataques reales y simulaciones con herramientas como Mimikatz y Cobalt Strike.
- *Uso en el Proyecto:* Prueba de resistencia y parseo binario para la regla base 100100.

3. Splunk Attack Data:

- *Descripción:* Trazas de ataques reproducibles empaquetadas por Splunk Threat Research Team.
- *Uso en el Proyecto:* Validación cruzada de eventos Sysmon y telemetría de red.

E.2 Fuentes de Ciberinteligencia Táctica

Group-IB Threat Intelligence: Reportes de adversarios operando en América Latina (FamousSparrow, Grandoreiro).

- **CISA Known Exploited Vulnerabilities (KEV) Catalog:** Catálogo oficial de vulnerabilidades con explotación activa en producción.
- **FBI InfraGard & CSIRT Alerts:** Boletines técnicos de patrones de ransomware dirigidos a infraestructura crítica.

Tabla 21: Matriz Resumen de Datasets Experimentales y Fuentes de Ciberinteligencia

Categoría de Fuente	Nombre de la Fuente / Repositorio	Tipo de Recurso	Formato de Datos	Propósito Metodológico en el Proyecto
Telemetría Experimental	Mordor Project (OTR)	Repositorio Abierto	JSON / EVTX	Ingesta de ataques simulados (T1059.001, T1078).
Telemetría Experimental	EVTX-ATTACK-SAMPLES	Repositorio Binario	.evtx (Windows)	Pruebas de resistencia y parseo de

				registros nativos.
Telemetría Experimental	Splunk Attack Data	Repositorio Técnico	JSON / Sysmon	Validación cruzada de eventos de red y procesos.
Ciberinteligencia Táctica	Group-IB Threat Intelligence	Reportes Especializados	STIX / PDF	Extracción de perfiles de actores con impacto regional.
Ciberinteligencia Táctica	CISA KEV Catalog	Base de Datos Oficial	JSON / CSV	Identificación de vulnerabilidades explotadas activamente.
Ciberinteligencia Táctica	FBI InfraGard / CSIRT	Boletines de Alerta	Textual / STIX	Modelado de campañas de ransomware y extorsión.

Nota. Caracterización técnica de las fuentes de información utilizadas para alimentar las capas de gobernanza de datos y el repositorio OpenCTI. OTR = Open Threat Research; KEV = Known Exploited Vulnerabilities. Elaboración propia.

ANEXO F: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)

Matriz de interoperabilidad y homologación sintáctica implementada por el pipeline de gobernanza en la fuente de origen:

Tabla 22: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)

Campo en Registro Crudo (EVTX / Sysmon / Splunk)	Campo Estandarizado (NDJSON / Wazuh)	Tipo de Dato	Regla de Validación Preanalítica	Alineación Normativa / Estándar
Event.System.EventID / EventCode	win.system.event_id	Integer	Obligatorio. Rango numérico válido de Windows Event Logs (ej. 4103, 4688, 7045).	PCI-DSS v4.0 (Req. 10.2)
Event.System.TimeCreated / _time	timestamp	ISO 8601	Obligatorio. Formato UTC estandarizado YYYY-MM-DDTHH:MM:SS.sssZ.	CNBS GE No. 342/2018 (Art. 21)
Event.EventData.CommandLine / cmdline	win.eventdata.command_line	String	Texto decodificado; rechaza cadenas nulas en eventos de ejecución de procesos.	MITRE ATT&CK (T1059)
Event.EventData.TargetUserName / user	win.eventdata.username	String	Formato normalizado DOMINIO\usuario o identificador de	MITRE ATT&CK

			cuenta local.	(T1078)
Event.EventData.Process Id / PID	win.eventdata.process_id	Integer	Identificador entero asignado por el kernel del sistema operativo.	NIST SP 800-207
Event.EventData.IpAddress / src_ip	network.source_ip	IPv4 / IPv6	Dirección IP válida; parseo y validación de sintaxis de red.	NIST SP 800-207
Technique_File / Simulated_Tag	attack_metadata.technique_file	String	Metadato de correlación del dataset sintético (ej. empire_mimikatz_opt h.tar.gz).	Mordor / Splunk Attack Data

Nota. Matriz de interoperabilidad y homologación sintáctica implementada por el script de gobernanza en la fuente de origen bajo el principio Zero Trust. PCI-DSS = Payment Card Industry Data Security Standard; NIST = National Institute of Standards and Technology. Elaboración propia.

ANEXO G: Instrumentos de Recolección de Datos (Actividad 2.1)

Tabla 23: Matriz de Alineación Metodológica: Objetivos, Variables e Instrumentos de Recolección

Objetivo Específico	Variable Asociada	Instrumento de Recolección	Tipo de Dato / Métrica
O1: Calibrar cuantitativamente el modelo de probabilidad geopolítica ($LO = II_{HN} + RI_{HN} + 0.2$) para Honduras.	X_1 : Mapeo Geopolítico	Instrumento 1: Plataforma de Orquestación OpenCTI, Mapeadores CSV (CSV Mappers) y Ficha de Ponderación CTI (Group-IB / CISA / FBI).	Exportaciones planas (CSV), grafos de conocimiento, y puntuaciones discretas II_{HN} y $RI_{HN} (FR_{SN})$
O2: Diseñar un framework técnico de gobernanza, normalización y certificación sintáctica de logs en origen.	X_2 : Nivel de Gobernanza de Datos	Instrumento 2: Estándares Ontológicos (STIX 2.1), Protocolos de Transporte M2M (TAXII 2.1) y Módulo de Certificación en Origen (NIST SP 800-207).	Objetos JSON/STIX 2.1, porcentaje (%) de error sintáctico, campos nulos y eventos por segundo (EPS).
O3: Modelar las secuencias de ataque y trayectorias de riesgo ante evasiones defensivas	X_3 : Mapeo Defensivo	Instrumento 3: Matrices Relacionales Taxonómicas (MITRE ATT&CK® Enterprise/ICS,	Mapeo de TTPs, secuencias temporales de ataque e identificadores de contramedidas defensivas (D3-

(Controls Override).		Attack Flow y MITRE D3FEND™ v1.4).	MFA, D3-NI).
O4: Evaluar el desempeño del framework reduciendo la fatiga de alertas sobre la muestra auditada ($n=137$).	Y : Efectividad Operativa del SOC	Instrumento 4: Consola de Correlación de Eventos (SIEM) como cámara de observación del <i>Sandbox</i> .	• Tasa de Falsos Positivos (% <i>TFP</i>). • Tiempo Medio de Detección (<i>MTTD</i>).
		Instrumento 5: Plantilla Automatizada de Extracción de Métricas (Scripts Python) y Protocolo de Benchmarking.	• Tiempo Medio de Respuesta (<i>MTTR</i>).

Nota. Matriz de operacionalización y correspondencia metodológica. CTI = Inteligencia de Amenazas Cibernéticas; SOC = Centro de Operaciones de Seguridad; SIEM = Gestión de Información y Eventos de Seguridad; *LO* = Probabilidad de Ocurrencia; $F R_{SN}$ = Factor de Riesgo a la Seguridad Nacional; *RI* = Interés Regional; *II* = Interés de Industria; *EPS* = Eventos por Segundo; *TFP* = Tasa de Falsos Positivos; *MTTD* = Tiempo Medio de Detección; *MTTR* = Tiempo Medio de Respuesta. Elaboración propia.

G.1 Instrumento 1: Plataforma de Orquestación OpenCTI, Mapeadores CSV (CSV

Mappers) y Ficha de Ponderación CTI

- **Propósito:** Instrumento tecnológico central de ingesta y modelado analítico. Procesa exportaciones planas (CSV) de inteligencia regional (Group-IB Threat Intelligence y fuentes públicas) mediante mapeadores estructurales (*CSV Mappers*), traduciéndolas a grafos de conocimiento en OpenCTI. Permite estructurar la información del atacante e inyectar algorítmicamente los pesos discretos de Industria de Interés (*II*) y Región de Interés (*RI*) para calibrar el Factor de Riesgo Único de Seguridad Nacional ($F R_{SN}$).
- **Alineación:** Objetivo Específico 1 y Variable Independiente X_1 (Mapeo Geopolítico).

Tabla 24: Ficha Técnica de Parámetros CTI y Mapeador CSV para el Factor de Riesgo Nacional (FR_{SN})

Componente	Especificación Técnica	Regla de Mapeo y Parametrización
Origen de Datos	Exportación Plana CSV	Reportes técnicos Group-IB, CISA KEV y FBI InfraGard.
Mecanismo de Procesamiento	OpenCTI CSV Mapper	Traducción semántica a Grafos de Conocimiento STIX 2.1.
Parametrización Algebraica	Modelo adaptado de Ahmed et al. (2022)	• Afinidad Regional Honduras (RI_{HN}): 0.40 (Campañas dirigidas a CA). • Afinidad Infraestructura Crítica (II_{HN}): 0.35 (Sector Financiero / Gobierno). • Constante Determinista de Fondo: 0.20 (Residuo

		de oportunidad).
<i>Cálculo de Probabilidad ($F R_{SN}$)</i>	Función Determinista	$F R_{SN} = I I_{HN} + R I_{HN} + 0.$ (Prioridad Crítica: FR_SN_CRITICAL).
<i>Atributos Mapeados (CSV)</i>	• Column_A (Threat Actor) • Column_B (Attack Vector) • Column_C (Target Sector)	→ Objeto STIX Threat-Actor (ej. <i>FamousSparrow</i> , <i>Grandoreiro</i>). → Objeto STIX Attack-Pattern (T1190, T1059.001, T1486). → Objeto STIX Identity (Infraestructura Crítica Nacional Honduras).

Nota. Especificación del Instrumento 1 para la parametrización de ciberinteligencia táctica. STIX = Structured Threat Information Expression; CA = Centroamérica. Elaboración propia.

G.2 Instrumento 2: Estándares Ontológicos (STIX 2.1), Protocolos TAXII 2.1 y Módulo de Certificación Zero Trust

- **Propósito:** Instrumentos semánticos y de transporte de datos máquina-a-máquina (M2M). Normalizan la telemetría y aseguran que la representación de las campañas mantenga integridad, fidelidad y cero degradación estructural en el tránsito entre OpenCTI y el entorno de monitoreo del SOC, cumpliendo con la norma NIST SP 800-207 y el Art. 21 de la Resolución GE No. 342/2018 de la CNBS.

- **Alineación:** Objetivo Específico 2 y Variable Independiente X_2 (Nivel de Gobernanza de Datos).

ALGORITMO 1: CERTIFICACIÓN DE INTEGRIDAD SINTÁCTICA Y GOBERNANZA M2M (PIPELINE ZTA)

Propósito: Validar y certificar la conformidad estructural de los registros lógicos

en origen bajo los principios de la norma NIST SP 800-207 y Art. 21 CNBS.

Entrada:

- Flujo crudo de telemetría y eventos lógicos (Raw_Log_Stream)
- Esquema de validación Zero Trust:

Mandatory_Schema = ["timestamp", "source_ip", "user_id", "event_id", "stix_pattern"]

Salida:

- Registro lógicamente certificado y puro (Log_Puro $\in$ Dp) o Rechazado por Ruido (Dr)

Inicio del Proceso:

1. Para cada evento lógico (Event_Item) recibido en Raw_Log_Stream:
2. Cargar la estructura del evento en formato JSON.
3. Inicializar indicador de conformidad: Flag_Conforme = TRUE.
4. Para cada campo obligatorio (Field) en Mandatory_Schema:

5. Si (Field NO está presente en Event_Item) O (Event_Item[Field] == NULL):
 6. Flag_Conforme = FALSE
 7. Registrar código de error: "ERR_CAMPO_NULO"
 8. Descartar evento del flujo activo (Aislar en subconjunto de ruido Dr)
 9. Romper ciclo de verificación
 10. Fin Si
 11. Fin Para
 12. Si Flag_Conforme == TRUE:
 13. Marcar evento como "CERTIFICADO_CONFORME_M2M" (Log perteneciente al conjunto Dp)
 14. Enviar evento purificado al motor de correlación del SIEM
 15. Fin Si
 16. Fin Para
- Fin del Proceso
-

G.3 Instrumento 3: Matrices Relacionales Taxonómicas (MITRE ATT&CK®, Attack Flow y MITRE D3FEND™ v1.4)

- **Propósito:** Instrumentos taxonómicos empleados como motores de reglas y especificaciones de diseño (*Design Requirements*). Mapean de forma granular las TTPs del adversario, construyen la secuencia temporal-condicional del ataque mediante MITRE Attack Flow y dictan la contramedida de ingeniería defensiva (MITRE D3FEND™ v1.4)

que el sistema debe orquestar ante técnicas de *Controls Override*.

- **Alineación:** Objetivo Específico 3 y Variable Independiente X_3 (Mapeo Defensivo MITRE D3FEND™).

Tabla 25: Mapeo Relacional Ofensivo-Defensivo basado en MITRE Attack Flow, ATT&CK® y D3FEND™

Secuencia (Attack Flow)	TTP Ofensiva (MITRE ATT&CK®)	Descripción de la Acción del Atacante	Contramedida Informativa (MITRE D3FEND™)	Identificador D3FEND (MITRE D3FEND Knowledge Graph, s. f.)
Paso 1	T1566.001: Spearphishing Attachment	Envío de correo malicioso con adjunto ejecutable al usuario.	File Content Analysis / Message Authentication	D3-FCA
Paso 2	T1059.001: PowerShell Execution	Ejecución de script ofuscado en memoria para evasión.	Script Execution Analysis / Process Lineage Validation	D3-SEA
Paso 3	T1078: Valid Accounts (<i>Controls Override</i>)	Intento de abuso de credenciales robadas para movimiento lateral.	Multi-Factor Authentication / User Behavior Analysis	D3-MFA
Paso 4	T1486: Data	Intento de	Network	D3-NI

Encrypted for	cifrado masivo	Isolation	/
Impact	de volúmenes	Process	
	en servidor	Eviction / File	
	crítico.	System	
		Hardening	

Nota. Matriz de interconexión semántica entre el flujo ofensivo y las contramedidas de mitigación técnica prescriptiva. TTP = Tácticas, Técnicas y Procedimientos; ATT&CK = Adversarial Tactics, Techniques, and Common Knowledge; D3FEND = Detection, Denial, and Disruption Framework, Empowering Network Defense. Elaboración propia a partir de MITRE Corporation (2024).

G.4 Instrumento 4: Consola de Correlación de Eventos (SIEM)

- Propósito:** Instrumento central de monitoreo experimental que opera como la "cámara de observación" del laboratorio (Sandbox). Ingiere la telemetría purificada, ejecuta las reglas de detección y audita el comportamiento del atacante, las marcas de tiempo (*timestamps*) y las respuestas del sistema ante la muestra experimental ($n=137$ registros lógicos).
- Alineación:** Objetivo Específico 4 y Variable Dependiente Y (Efectividad Operativa del SOC).

Tabla 26: Ficha de Registro de la Cámara de Observación (SIEM Log Audit) para la Muestra Auditada ($n = 137$)

ID Registr o (n)	Timestamp Ejecución (t_0)	Timestamp Alerta SIEM (t_1)	Timestamp Control (t_2)	$MTTD$ (t_1-t_0)	$MTTR$ (t_2-t_1)	Clasificació n Real	¿Es Falso Positivo ?
Log-00 1	10:00:02.10 0	10:00:03.25 0	10:00:05.10 0	1.15 seg	1.85 seg	Ataque Verídico	No
Log-00 2	10:01:15.05 0	10:01:15.20 0	N/A	0.15 seg	N/A	Ruido Benigno	Si
...	...	...	...	...	...	...	...
Log-13 7	11:45:10.80 0	11:45:11.95 0	11:45:13.20 0	1.15 seg	1.25 seg	Ataque Verídico	No

Nota. Registro de auditoría temporal y diagnóstica extraído desde la consola SIEM para el cálculo de las métricas operativas. t_0 = Timestamp de ejecución; t_1 = Timestamp de alerta en SIEM; t_2 = Timestamp de control desplegado; *MTTD* = Tiempo Medio de Detección; *MTTR* = Tiempo Medio de Respuesta; *TP* = Verdadero Positivo; *FP* = Falso Positivo; N/A = No Aplica. Elaboración propia.

G.5 Instrumento 5: Plantilla Automatizada de Extracción de Métricas (Scripts Python) y Protocolo de Benchmarking

- **Propósito:** Instrumento de medición algorítmica (*Benchmarking Probe*). Extrae de forma programática la muestra finita y purificada de $n=137$ eventos desde la base de datos del SIEM, capturando con precisión de milisegundos las marcas de tiempo de inyección, alertamiento y contención.
- **Alineación:** Objetivo Específico 4, contraste de hipótesis (H_0 vs. H_1) y Variable Dependiente Y (*TFP*, *MTTD*, *MTTR*).

ALGORITMO 2: EXTRACCIÓN Y CÁLCULO DE MÉTRICAS OPERATIVAS DEL SOC ($n = 137$)

Propósito: Automatizar el procesamiento de los 137 eventos auditados de la muestra extraída del SIEM para cuantificar la Variable Dependiente (Y).

Entrada:

- Muestra estadística purificada de eventos auditados (Muestra_CSV_137)

Salida:

- Tasa de Falsos Positivos (TFP_Porcentaje)
- Tiempo Medio de Detección Promedio (MTTD_Promedio)
- Tiempo Medio de Respuesta Promedio (MTTR_Promedio)

Inicio del Proceso:

1. Cargar Muestra_CSV_137 en un espacio de análisis tabular estructurado.
2. Contar el número total de registros analizados (Total_Alertas = Total de filas).
3. Filtrar los registros cuya clasificación real sea un Falso Positivo (Count_FP).

4. [Cálculo Estadístico de Tasa de Falsos Positivos - TFP]:

$$\text{TFP_Porcentaje} = (\text{Count_FP} / \text{Total_Alertas}) * 100$$

5. [Cálculo de Tiempo Medio de Detección - MTDD]:

Para cada registro i en la muestra (desde 1 hasta n):

$$\text{MTDD_Individual}[i] = \text{Timestamp_Alerta_SIEM}[i] - \text{Timestamp_Ejecucion_TTP}[i]$$

Fin Para

$$\text{MTDD_Promedio} = (1 / n) * \text{Sumatoria}(\text{MTDD_Individual})$$

6. [Cálculo de Tiempo Medio de Respuesta - MTTR]:

Para cada registro j que posea un control defensivo ejecutado (desde 1 hasta m):

$$\text{MTTR_Individual}[j] = \text{Timestamp_Despliegue_Control}[j] - \text{Timestamp_Alerta_SIEM}[j]$$

Fin Para

$$\text{MTTR_Promedio} = (1 / m) * \text{Sumatoria}(\text{MTTR_Individual})$$

7. Consolidar, presentar y exportar los indicadores estadísticos para el contraste formal con la Hipótesis de Investigación (H1).

Fin del Proceso

